CASE STUDY

The Year 2007 in Intrusions: A Dated Record

A TeamStarWolf case study. Published 13 November 2026; every source checked as of that date.

Executive summary

The year opened with two stories that set its tone. On 12 January a trojan dropped by an e-mail virus later named the Storm Worm began flooding anti-spam sites, and on 30 January it hit Spamhaus, which SecureWorks thought was an accident after spammers repointed DNS records (Reported [1]). SecureWorks' analysis of 7 February describes a second-stage download located through an adapted eDonkey/Overnet protocol with more than 100 hard-coded peers, so that no single hosting site held the address, and a denial-of-service component that ran TCP SYN and ICMP floods (Confirmed [1]). Five days after the first floods, on 17 January, the retailer TJX announced an unauthorized intrusion into the systems that handle customer transaction data for its US, Puerto Rico and Canadian chains (Confirmed [2]). Its annual report later said the intruder had first got in during July 2005, had access to the decryption tool for TJX's encryption software, and took card data that the filing's own table puts at about 45.6 million cards (Confirmed [4]). The case is told in full in E-Commerce Threats; this study records its 2007 filings, regulators and settlements.

The year's political event came in the spring. After the Bronze Soldier memorial was moved, denial-of-service attacks on Estonian government websites began late on 27 April and spread to media and banks. A NATO cooperative centre's later analysis, built on the State Informatics Centre's timeline, records waves through 18 May, with computers in 178 countries taking part and online banking disturbed on 9 and 10 May (Reported [40]). Prime Minister Ansip accused the Russian government, and Moscow denied any part in it (Reported [42]). The only conviction by summer 2009 was an Estonian student, fined for ping floods against one party's website, and Russia refused Estonia's request for legal assistance (Reported [40]). NATO's own page says the attacks made cyber defence urgent for Allied defence ministers, and the Alliance adopted its first cyber defence policy in January 2008 (Confirmed [45]). This study is the home for Estonia 2007 in the library.

The working attack surface was the document, the web page and the Windows network service. Microsoft bulletins say Word (February), Excel (February), the Windows animated cursor (April) and the DNS Server

RPC interface (May) were all being exploited when their fixes shipped (Confirmed [11][12][19][23]). US-CERT reported a worm against the Solaris telnet daemon in February and malicious PDF files abusing a Windows URI flaw in October (Confirmed [14][29]). Only three CVE-2007 ids are in CISA's Known Exploited Vulnerabilities catalog today, and one of them, the Excel flaw, was added in August 2025 (Confirmed [37]).

Much of the state record for 2007 was written in arrears. Der Spiegel reported Chinese spyware in the German Chancellery and three ministries, and the BBC reported US officials blaming the PLA for a Pentagon intrusion, and the Guardian reported Whitehall officials saying Chinese hackers, some believed to be PLA, had attacked UK government networks (Reported [54][56][57]). Vendor reports published from 2012 to 2014 date APT1 tooling, APT28, Darkhotel tools, Red October and Careto to 2007, and Symantec dates Stuxnet 0.5 to November 2007 (Confirmed [60][66][69][71][72][62]). None of those reports was public in 2007.

Two of the year's large data losses involved no network intrusion. A database administrator at Certegy sold about 2.3 million consumer records, and two unregistered discs with child benefit data on 25 million people went missing in the post between two UK government bodies (Confirmed [50][53]). Law enforcement ran two rounds of Operation Bot Roast, and the year closed with a new rulebook: OMB's one-hour breach reporting rule, the Red Flags rule, a chemical-plant cyber standard, a FERC proposal on the NERC CIP standards, CVSS version 2, DKIM, the OWASP Top 10 2007, the public start of CAPEC and NIST's SHA-3 competition (Confirmed [75][80][76][77][83][84][90][93][89]).

This study records the year by date. It is built only from sources opened on 12 November 2026 and checks of the library's data run on 13 November 2026, and is checked as of 13 November 2026.

Key facts at a glance

Field	Value
Period	1 January to 31 December 2007, plus the records that open or close a 2007 event: TJX's intrusion from July 2005, the FTC's TJX settlement (2008), the Gonzalez charges (2008), Russia's 2008 reply to Estonia, NATO's January 2008 policy, CCDCOE's founding (2008), the later vendor reports (2012 to 2014) and the KEV additions (2022 and 2025)
Botnets	Storm Worm floods on anti-spam sites from 12 Jan, Spamhaus on 30 Jan; Soloway arrested 30 May; Operation Bot Roast (13 Jun, over 1 million victim IP addresses); Bot Roast II (29 Nov, eight individuals, over $20 million in losses) (Reported [1]; Confirmed [1][46][47][48])
Estonia	DDoS from 27 Apr to 18 May with some aftermath to end of May; government, parliament, president, ministries, parties, e-banking and news sites; one conviction; Russia refused legal assistance (Reported [40][41]; Confirmed [45])
Corporate and data losses	TJX announced 17 Jan (about 45.6 million cards per its 10-K table); Certegy insider sale (about 2.3 million records, announced 3 Jul); TD Ameritrade database code found (announced 14 Sep); HMRC discs lost (25 million individuals, statement 20 Nov) (Confirmed [2][4][50][51][53])
Exploited at release	MS07-014 (Word) and MS07-015 (Excel), 13 Feb; MS07-017 (animated cursor), 3 Apr; MS07-029 (DNS Server RPC), 8 May (Confirmed [11][12][19][23])
US-CERT alerts on active exploitation	Solaris telnet worm (28 Feb); animated cursor (30 Mar); DNS RPC (13 Apr); URI handling via PDF (24 Oct); QuickTime RTSP exploit code public (25 Nov) (Confirmed [14][18][21][29][33])
CVE and KEV	CVE in place since 1999; 2,475 CVE records published from 1 Jan to 30 Apr (full year not counted); three CVE-2007 ids in KEV (CVE-2007-3010, CVE-2007-5659, CVE-2007-0671), added 2022 and 2025 (Demonstrated [39]; Confirmed [37])
Microsoft	MS07-001 (9 Jan) to MS07-069 (11 Dec); MS07-070 does not exist (Confirmed [38]; the total of 69 is Inferred)
State record at the time	German Chancellery and ministries (Spiegel, 25 Aug); Pentagon, June (BBC citing the FT); UK departments (Guardian, 4 Sep); MI5 letter to 300 firms (BBC, 2 Dec); Cartwright testimony on Chinese reconnaissance (29 Mar) (Reported [54][56][57][58]; Confirmed [43])
State record written later	APT1's first MANITSME sample (29 Jun 2007) and BISCUIT use from 2007; APT28 from 2007 (FireEye); APT5 from 2007 (ATT&CK); Darkhotel tools from 2007; Red October from about May 2007; Careto from 2007; Stuxnet 0.5 in the wild by Nov 2007; a Flame filename seen 5 Dec 2007 (Confirmed [60][66][68][69][71][72][62][64])
Industrial	Stuxnet 0.5 submitted to a public scanning service 15 Nov; the Aurora generator test (March, Reported); CFATS cyber standard (9 Apr); FERC CIP proposal (6 Aug) (Confirmed [62][76][77]; Reported [59])
Law and policy	Identity theft strategic plan (Apr); OMB M-07-16 (22 May); Minnesota card-data law (21 May); CCDCOE-recorded letter rogatory (10 May); Scotland's computer misuse commencement (1 Oct); California AB 1298 (14 Oct); Red Flags rule (9 Nov) (Confirmed [74][75][78][81][79][80]; Reported [40])
Standards	NIST SP 800-94 (20 Feb); SP 800-90 (2006) withdrawn and superseded (14 Mar); CAPEC website (17 Mar); RFC 4871 DKIM (May); CVSS v2 (20 Jun); SHA-3 competition (2 Nov); SP 800-38D GCM (28 Nov); OWASP Top 10 2007; CWE Drafts 6 and 7 (Confirmed [85][87][91][84][83][89][86][90])

Field	Value
This study's MITRE binding	17 ATT&CK Enterprise techniques in 20 technique-tactic entries, all later mappings; two ATT&CK for ICS rows for Stuxnet 0.5; APT1 (G0006), BISCUIT (S0017), APT28 (G0007), APT5 (G1023), Darkhotel (G0012), Stuxnet (S0603) and BlackEnergy (S0089) bound with dating caveats; no campaign object; NVD's CWE-88, CWE-119, CWE-20, CWE-77, CWE-120 and CWE-22 plus study-class CWEs; CAPEC and D3FEND pairings from the library's data; one Enterprise and one ICS Navigator layer (Part 9)

Key findings

- **The botnet became the platform.** SecureWorks describes Storm as a trojan whose second stage was found through a peer-to-peer network with no single host, plus a flood component, and describes at least three independent botnets (Confirmed [1]). The FBI's June announcement identified more than 1 million victim IP addresses, and its November update put the operation's running total at more than one million victim computers (Confirmed [47][48]).
- **Estonia was a denial-of-service campaign, not a proven state attack.** The record shows three weeks of floods, defacements and DNS attacks against Estonia's government, banks and media, one local conviction, a refused request for legal help, and a state attribution that Estonia's prime minister made and Russia denied (Reported [40][41][42]). The USCC wrote "allegedly by hackers from Russia" (Confirmed [43]).
- **Office and Windows flaws were exploited before fixes existed.** Four Microsoft bulletins from February to May say flaws were being exploited at release, and US-CERT warned of the DNS RPC flaw before any complete fix (Confirmed [11][12][19][21][23]).
- **TJX's discovery came about seventeen months after first access.** The intrusion began in July 2005 and was found in December 2006, and the intruder could reach TJX's decryption tool (Confirmed [4]; the interval is Inferred). Canada's privacy commissioners found that TJX relied on WEP and did not meet Canadian safeguard rules (Confirmed [5]).
- **Two large record losses were an insider sale and a lost parcel.** Certegy's data left "via physical processes; not electronic transmission", and HMRC's discs went by unregistered internal post (Confirmed [50][53]).
- **The 2007 espionage record was mostly press reporting at the time.** German, US and UK officials were quoted, unnamed or by role, and China denied three of the four reports (Reported [54][56][57][58]). The firm dates came years later, from vendors, and most of those reports name no state (Confirmed [60][62][69][71][72]).
- **Old flaws stay live.** CISA added two CVE-2007 ids to KEV in 2022 and a third in 2025, 18 years after the Excel flaw was patched (Confirmed [37]; the interval is Inferred).
- **2007 laid down the vocabulary.** CVSS v2, DKIM, the OWASP Top 10 2007 with CWE ids on every category, CAPEC's public start and NIST's IDPS guide all date from this year (Confirmed [83][84][90][93][85]).

Top recommendations

1. **Plan for the flaw with no patch.** The animated cursor and DNS RPC flaws were exploited before Microsoft's fixes, and US-CERT knew of no complete fix for the DNS flaw on 13 April (Confirmed [16][18][21]).
2. **Treat Office files and PDFs from outside as untrusted code.** Word and Excel flaws were exploited at release, and PDF files were used to reach a Windows URI flaw (Confirmed [11][12][29]).
3. **Turn off what you do not need, especially old remote-login services.** The Solaris telnet worm used a flaw in the telnet daemon to log in as the adm or lp users (Confirmed [14]).
4. **Lock down wireless and encrypt the card path.** Canada's commissioners found TJX relied on WEP, and TJX's own filing says card data was sent unencrypted during issuer approval (Confirmed [5][4]).
5. **Watch the insider with database rights.** Certegy's loss was a senior database administrator selling records (Confirmed [50]).
6. **Track physical media like money.** HMRC's discs travelled unrecorded and unregistered (Confirmed [53]).
7. **Have a denial-of-service plan with your upstream providers.** Hansapank, Estonia's largest commercial bank, had its online banking down for about 1.5 hours on 9 May and two hours on 10 May (Reported [40]). The library's incident response reference covers escalation paths (Inferred).
8. **Report fast.** OMB's M-07-16 required agencies to report every incident involving personal information to US-CERT within one hour of discovery (Confirmed [75]).
9. **Authenticate your mail.** RFC 4871 (DKIM) became a Proposed Standard in May, and the FTC was spoofed in October to deliver malware (Confirmed [84][32]).
10. **Score and prioritize with a common scale, then check KEV.** CVSS v2 arrived on 20 June, and KEV now flags three CVE-2007 ids as exploited (Confirmed [83][37]).

Scope and method

This study covers intrusions, vulnerabilities, malware, data losses, prosecutions, espionage reporting, industrial security, regulation, standards and policy dated to 2007, plus the later records that open, close or explain a 2007 event. It follows the method of the case studies collection: primary sources first, every claim graded, and numbers given as the source states them. Sources were opened on 12 November 2026, and the library data checks were run on 13 November 2026.

Grade	Meaning in this study
Confirmed	The primary record was opened and states the fact: a vendor bulletin or advisory, a CERT/CC note, a US-CERT alert in CISA's archive, an NVD record, the KEV catalog, a Justice Department, US Attorney or FBI release, an indictment, an SEC filing, an FTC release, a Canadian privacy commissioners' report, a parliamentary record, a statute, regulation or Federal Register notice, an OMB memorandum, a NIST, IETF, FIRST, OWASP or MITRE record, a NATO or CCDCOE institutional page, a congressional commission report, a vendor research report stated as that vendor's own finding, a live ATT&CK page, or a library study, only for the fact that it is the home for an event

Grade	Meaning in this study
Reported	Only a secondary source supports the fact, or a source gives a reading or judgement that is its own: the CCDCOE analyses of Estonia (which say they are not an official NATO position), the BBC, the Guardian, CNN and Der Spiegel, and SecureWorks' reading that the Spamhaus attack was an accident. The source is named in the text
Demonstrated	A check this study ran itself and saw the result: the NVD count, the KEV count, and id, name, tactic and page checks in the library's data files and `mitre/` page tree
Inferred	The study's own reading, labelled where it appears. Every ATT&CK, CAPEC and D3FEND id bound to a 2007 event is Inferred as to the binding, and so is every CWE that NVD does not list

Indictments and complaints are allegations; where this study cites one, the record confirms that the allegation was made, not that it was proven. Company filings are the company's own account, and vendor attributions are those vendors' assessments, not government findings.

Limits a reader should know:

- **CVE existed; ATT&CK and KEV did not, and CVSS v2 arrived mid-year.** Every 2007 vulnerability here carries a CVE id. FIRST released CVSS v2 on 20 June 2007, so a v2 score on a record published earlier in the year was added afterwards (Confirmed [83]; Inferred for the retrofit). ATT&CK came years later, so no 2007 record carries an ATT&CK id, and every technique in Part 9 is this study's later mapping unless ATT&CK itself dates the object to 2007 (Inferred). KEV added its three CVE-2007 entries in 2022 and 2025 (Confirmed [37]).
- **CWE was a draft and CAPEC was new.** CWE Draft 6 was posted on 7 May 2007 and Draft 7 on 1 October, and CWE version 1.0 did not come until 9 September 2008 (Confirmed [91][92]). CAPEC's companion website went up on 17 March 2007 and CAPEC describes itself as initially released in 2007 (Confirmed [91][93]). The CWE ids NVD now lists for 2007 flaws were assigned after the fact (Inferred).
- **What was not checked.** No primary was opened for: the Pentagon e-mail intrusion beyond the BBC's account of the FT story; the MI5 letter itself; the Defense Department's 2008 report on the Chinese military; GAO-07-705, GAO-07-737 and GAO-07-1036; NRC Information Notice 2007-15; the McKinnon High Court judgment of 2007; the Butler sentencing release; the 2009 Gonzalez charges on Heartland and Hannaford; Microsoft bulletin MS07-061; Adobe bulletin APSB07-18; OMB M-07-11 and the date of the FDCC mandate; the Council of Europe Cybercrime Convention's entry into force for the United States; the text of California AB 1298; the Bundesgesetzblatt date for German StGB section 202c; ISO/IEC 27002's renumbering; the CA/Browser Forum's EV Guidelines; the Russian Business Network; MPack; Gozi; the first ZeuS sightings; Monster.com's job-seeker data theft; Operation Orchard; the provisional Air Force Cyber Command; any Storm botnet size figure; and the full-year NVD count. They are left out or marked "not checked" where they touch a verified fact. Their absence here is not evidence that nothing happened.

Part 1: the year as a dated timeline

One row per event or report. The date is the event date where the source gives one, otherwise the publication date. Rows marked "frame" or "boundary" open or close a 2007 event.

Date	Event	Thread	Sector	Grade	Sources
2003-11 to 2007-05 (frame)	Robert Soloway allegedly sends spam with forged headers relayed through botnets	Crime	Internet, consumers	Confirmed (as alleged)	[46]
2005-06 (frame)	Max Butler's alleged intrusions into financial institutions and card processors begin. Home: Four Books on Cybercrime	Crime	Financial services	Confirmed (as alleged)	[52]
2005-07 to 2007-01 (frame)	TJX intruder's access: July 2005, later 2005, and mid-May 2006 to mid-January 2007. Home: E-Commerce Threats	Intrusion	Retail	Confirmed	[4][97]
2005-11-03 (frame)	Stuxnet 0.5 command servers registered. Home: Stuxnet	Industrial	Energy (nuclear)	Confirmed	[62]
2006-12-18 (frame)	TJX finds suspicious software	Intrusion	Retail	Confirmed	[4]
2007-01-01	NVD publishes CVE-2007-0015, a QuickTime rtsp:// URI overflow	Vulnerability	Cross-sector	Confirmed	[28]
2007-01-09	MS07-001, the year's first Microsoft bulletin	Vulnerability	Technology	Confirmed	[38]
2007-01-12	Storm floods several anti-spam sites	Botnet	Internet, anti-spam	Confirmed	[1]
2007-01-17	TJX announces the intrusion (8-K signed 18 Jan)	Intrusion	Retail	Confirmed	[2]
2007-01-25	Windows Vista lifecycle start date (original release)	Platform	Technology	Confirmed	[94]
2007-01-30	Storm floods Spamhaus, apparently by accident (SecureWorks' reading)	Botnet	Internet, anti-spam	Reported	[1]
2007-02-03	NVD publishes CVE-2007-0671, the Excel flaw used in targeted zero-day attacks	Vulnerability	Cross-sector	Confirmed	[13]
2007-02-07	SecureWorks publishes its Storm Worm DDoS analysis	Botnet	Internet	Confirmed	[1]
2007-02-12	NVD publishes CVE-2007-0882, the Solaris telnet flaw	Vulnerability	Cross-sector	Confirmed	[15]
2007-02-13	MS07-014 (Word) and MS07-015 (Excel), both exploited at release	Vulnerability	Cross-sector	Confirmed	[11][12]
2007-02-20	NIST SP 800-94, intrusion detection and prevention	Standards	Cross-sector	Confirmed	[85]
2007-02-21	TJX: intrusions also in July 2005 and later 2005; card data from January 2003 to June 2004 transactions compromised	Intrusion	Retail	Confirmed	[3]

Date	Event	Thread	Sector	Grade	Sources
2007-02-28	US-CERT TA07-059A: worm exploits the Solaris telnet daemon	Worm	Cross-sector	Confirmed	[14]
2007-03	Aurora generator test at the Idaho lab (date per CNN, 26 Sep)	Industrial	Energy	Reported	[59]
2007-03-14	NIST SP 800-90 (June 2006) withdrawn and superseded	Standards	Cross-sector	Confirmed	[87]
2007-03-17	MITRE launches a companion website for CAPEC	Standards	Cross-sector	Confirmed	[91]
2007-03-28	TJX 10-K: 45.6 million cards in the filing's table; access to the decryption tool	Intrusion	Retail	Confirmed	[4]
2007-03-29	Cartwright testifies on Chinese cyber reconnaissance; animated cursor flaw made public (VU#191609); Advisory 935423 (29 or 31 Mar)	Espionage; Vulnerability	Government; cross-sector	Confirmed	[43][17][16]
2007-03-30	US-CERT TA07-089A: animated cursor flaw actively exploited	Exploitation	Cross-sector	Confirmed	[18]
2007-04-03	MS07-017 fixes the animated cursor flaw, a week before the monthly release	Vulnerability	Cross-sector	Confirmed	[19]
2007-04-09	DHS Chemical Facility Anti-Terrorism Standards interim final rule, with a cyber performance standard	Regulation	Chemical	Confirmed	[76]
2007-04-13	US-CERT TA07-103A: DNS Server RPC flaw actively exploited, no complete fix	Exploitation	Cross-sector	Confirmed	[21][22]
2007-04-20	QuickTime for Java flaw made public; CERT/CC says it was demonstrated at CanSecWest	Vulnerability	Cross-sector	Confirmed	[25]
2007-04-23	Identity Theft Task Force strategic plan submitted	Policy	Cross-sector	Confirmed	[74]
2007-04-25 to 2007-05-04	Galushkevich's admitted ping floods on the Reform Party website	Estonia	Politics	Reported	[40]
2007-04-27	DDoS on Estonian government websites begins after the Bronze Soldier relocation	Estonia	Government	Reported	[40]
2007-05	RFC 4871, DKIM; Red October's earliest evidence (possibly May)	Standards; Espionage	Internet; diplomatic	Confirmed	[84][71]
2007-05-01	ZDI-07-023 published for the QuickTime Java flaw	Vulnerability	Cross-sector	Confirmed	[26]
2007-05-03	Estonia attacks spread to media and private firms	Estonia	Media, private sector	Reported	[40]

Date	Event	Thread	Sector	Grade	Sources
2007-05-07	CWE Draft 6	Standards	Cross-sector	Confirmed	[91]
2007-05-08	MS07-029 fixes the DNS Server RPC flaw	Vulnerability	Cross-sector	Confirmed	[23]
2007-05-09 to 2007-05-11	Estonia wave with attempts at a "cyber blockade"; e-banking outages on 9 and 10 May	Estonia	Banking	Reported	[40]
2007-05-10	Estonia sends Russia a letter rogatory	Estonia	Government	Reported	[40]
2007-05-15	Estonia wave; CERT-EE reports a botnet of about 85,000 computers; SEB Eesti Uhispank attacked	Estonia	Government, banking	Reported	[40]
2007-05-17	BBC: Estonia's prime minister accuses the Russian government; NATO sends an expert	Estonia	Government	Reported	[42]
2007-05-18	Estonia attacks end, with some aftermath to the end of May	Estonia	Government	Reported	[40]
2007-05-21	Minnesota card-data retention law signed	Law	Retail, payments	Confirmed	[78]
2007-05-22	OMB M-07-16: one-hour reporting of PII incidents	Policy	Government	Confirmed	[75]
2007-05-26	MITRE posts its updated vulnerability type distributions white paper	Standards	Cross-sector	Confirmed	[91]
2007-05-30	Soloway arrested	Crime	Internet	Confirmed (as alleged)	[46]
2007-05-31	Elvey class action alleges TD Ameritrade e-mail addresses reached spammers	Breach	Brokerage	Confirmed	[51]
2007-06	Pentagon: a system of the Defense Secretary's office hacked, per US officials quoted by the FT	Espionage	Government, defense	Reported	[56]
2007-06-13	Operation Bot Roast announced	Crime	Law enforcement	Confirmed	[47]
2007-06-20	FIRST releases CVSS v2	Standards	Cross-sector	Confirmed	[83]
2007-06-29	Date signed in APT1's first known MANITSME sample (Mandiant)	Espionage	Unknown	Confirmed	[60]
2007-07-03	FIS announces Certegy's insider data theft	Breach	Financial services	Confirmed	[50]
2007-08	CRYPTO 2007 rump session: Shumow and Ferguson on Dual EC (month not checked separately)	Standards	Cross-sector	Confirmed	[88]

Date	Event	Thread	Sector	Grade	Sources
2007-08-06	FERC proposes approving the NERC CIP standards	Regulation	Energy	Confirmed	[77]
2007-08-25	Der Spiegel: Chinese spyware in the Chancellery and three ministries	Espionage	Government	Reported	[54]
2007-08-28	NVD publishes CVE-2007-4559, Python tarfile directory traversal	Vulnerability	Software	Confirmed	[36]
2007-09-04	BBC on the Pentagon report; Guardian on UK departments	Espionage	Government	Reported	[56][57]
2007-09-05 and 2007-09-11	Max Butler arrested and indicted. Home: Four Books on Cybercrime	Crime	Financial services	Confirmed (as alleged)	[52][98]
2007-09-14	TD Ameritrade announces it found and removed unauthorized code	Breach	Brokerage	Confirmed	[51]
2007-09-18	NVD publishes CVE-2007-3010, Alcatel OmniPCX command execution	Vulnerability	Telecommunications	Confirmed	[34]
2007-09-21	TJX class settlement signed; NVD publishes CVE-2007-5020 (Acrobat mailto)	Litigation; Vulnerability	Retail; cross-sector	Confirmed	[6][31]
2007-09-24	Sweaney pleads guilty (Bot Roast II)	Crime	Internet	Confirmed	[48]
2007-09-25	Canadian privacy commissioners report on TJX and Winners	Regulation	Retail	Confirmed	[5]
2007-09-26	CNN reports the Aurora test; class action against TD Ameritrade	Industrial; Breach	Energy; brokerage	Reported; Confirmed	[59][51]
2007-10-01	CWE Draft 7; Scotland commencement of the Police and Justice Act computer misuse sections	Standards; Law	Cross-sector	Confirmed	[91][81]
2007-10-11	NVD publishes CVE-2007-3896, the Windows URI handling flaw	Vulnerability	Cross-sector	Confirmed	[30]
2007-10-12	Paskalov sentenced to 42 months for phishing (Bot Roast II)	Crime	Banking	Confirmed	[48]
2007-10-14	California AB 1298 chaptered	Law	Cross-sector	Confirmed	[79]
2007-10-18 (about)	HMRC child benefit discs sent to the NAO by internal post	Data loss	Government	Confirmed	[53]
2007-10-24	US-CERT TA07-297B: URI flaw exploited with malicious PDF files	Exploitation	Cross-sector	Confirmed	[29]
2007-10-30	US-CERT SA07-303A: spoofed FTC e-mail with malicious attachments	Phishing	Consumers	Confirmed	[32]
2007-11	USCC annual report; Stuxnet 0.5 in the wild as early as this month	Espionage; Industrial	Government; energy	Confirmed	[43][62]

Date	Event	Thread	Sector	Grade	Sources
2007-11-01	Goldstein indicted for a botnet DDoS on a university (Bot Roast II)	Crime	Education	Confirmed (as alleged)	[48]
2007-11-02	NIST announces the SHA-3 competition	Standards	Cross-sector	Confirmed	[89]
2007-11-09	Identity Theft Red Flags final rules	Regulation	Financial services	Confirmed	[80]
2007-11-15	Stuxnet 0.5 submitted to a public scanning service	Industrial	Energy (nuclear)	Confirmed	[62]
2007-11-20	Chancellor tells the Commons the HMRC discs are missing	Data loss	Government	Confirmed	[53]
2007-11-25	Exploit code for the QuickTime RTSP flaw posted publicly	Vulnerability	Cross-sector	Confirmed	[33]
2007-11-26	TD Ameritrade 10-K	Breach	Brokerage	Confirmed	[51]
2007-11-28	NIST SP 800-38D, GCM and GMAC	Standards	Cross-sector	Confirmed	[86]
2007-11-29	Bot Roast II announced; TJX settles US Visa issuer claims (8-K filed 30 Nov)	Crime; Litigation	Law enforcement; retail	Confirmed	[48][49][7]
2007-11-30	US-CERT TA07-334A on QuickTime RTSP	Vulnerability	Cross-sector	Confirmed	[33]
2007-12-02	BBC: MI5 warns 300 firms of Chinese state spying	Espionage	Financial services	Reported	[58]
2007-12-05	A Flame main-component filename first seen, in Europe	Espionage	Unknown	Confirmed	[64]
2007-12-06	CWE difference reports posted	Standards	Cross-sector	Confirmed	[91]
2007-12-11	MS07-069, the year's last Microsoft bulletin	Vulnerability	Technology	Confirmed	[38]
2007-12-13	Harju County Court convicts Dmitri Galushkevich for ping floods on the Reform Party website (judgment cited by CCDCOE)	Estonia	Politics	Reported	[40]
2008-01 (boundary)	NATO approves its first Policy on Cyber Defence	Policy	Defense	Confirmed	[45]
2008-02-12 (boundary)	NVD publishes CVE-2007-5659 (Adobe Reader JavaScript overflows)	Vulnerability	Cross-sector	Confirmed	[35]
2008-03-27 (boundary)	FTC announces its TJX settlement	Regulation	Retail	Confirmed	[8][9]
2008-05-14 (boundary)	CCDCOE established in Tallinn	Policy	Defense	Confirmed	[44]

Date	Event	Thread	Sector	Grade	Sources
2008-06-28 (boundary)	Russia refuses Estonia's legal assistance request	Estonia	Government	Reported	[40]
2008-08-05 (boundary)	DOJ charges Albert Gonzalez and ten others, including over TJX	Crime	Retail	Confirmed (as alleged)	[10]
2013-02 (boundary)	Mandiant publishes its APT1 report; Symantec publishes Stuxnet 0.5 (26 Feb)	Espionage; Industrial	Cross-sector	Confirmed	[60][62]
2014-10-27 (boundary)	FireEye dates APT28 activity to at least 2007	Espionage	Government, defense	Confirmed	[66]
2022-04-15, 2022-06-08 and 2025-08-12 (boundary)	KEV adds CVE-2007-3010, CVE-2007-5659 and CVE-2007-0671	Vulnerability	Cross-sector	Confirmed	[37]

Part 2: Storm and the botnet economy

The Storm Worm

Joe Stewart's analysis for SecureWorks' Counter Threat Unit, dated 7 February 2007 and now hosted by Sophos, is the one primary opened here on Storm (Confirmed [1]). It names the trojan's dropper as an e-mail virus later called the Storm Worm, also tracked as W32/Small.DAM and Trojan.Peacomm and earlier as Win32/Nuwar, with variants from November and December 2006 and early January 2007 (Confirmed [1]). Its denial-of-service component began flooding several anti-spam sites on 12 January 2007 (Confirmed [1]). Spamhaus was hit on 30 January. SecureWorks thought that was apparently an accident, after spammers repointed DNS records, and that reading is the vendor's own (Reported [1]).

Two design points make Storm the year's technical story. The author adapted the eDonkey/Overnet peer-to-peer protocol to hand out the address of the second-stage download, with over 100 peers hard-coded, so that no single hosting site held the address (Confirmed [1]). The flood component ran TCP SYN floods on port 80 and ICMP floods, and SecureWorks describes at least three independent botnets (Confirmed [1]). The analysis gives no count of infected machines, and this study states none (Confirmed [1]; see "What is overstated").

ATT&CK has no software object for Storm, Peacomm or Nuwar in the library's data, so no S id is bound (Demonstrated [100]).

Soloway and the spam botnets

The US Attorney for the Western District of Washington announced on 30 May 2007 that Robert Alan Soloway had been arrested on an indictment for mail fraud, wire fraud, fraud in connection with electronic mail, aggravated identity theft and money laundering. It alleges that from November 2003 to May 2007 he sent spam with forged headers relayed through botnets (Confirmed [46]; allegations). The FBI's Bot Roast release lists Soloway's case among its charges and describes it as botnet-driven spam of tens of millions of messages (Confirmed [47]).

Operation Bot Roast

On 13 June 2007 the Justice Department and the FBI announced Operation Bot Roast, a national initiative against botnet herders. It had identified more than 1 million victim computer IP addresses, and the FBI was working with the CERT Coordination Center to notify the owners (Confirmed [47]). The cases charged under the federal computer crime statute were James C. Brewer, whose botnet infected Chicago-area hospitals, Jason Michael Downey, for denial-of-service attacks through botnets, and Soloway (Confirmed [47]; allegations).

The FBI's second round, announced on 29 November, counted eight individuals indicted, pleading guilty or sentenced since June, and 13 search warrants served in the United States and abroad, with more than $20 million in economic loss and more than one million victim computers uncovered (Confirmed [48]). The cases include Goldstein, indicted on 1 November for a botnet denial-of-service attack on a Philadelphia-area university; Sweaney, who pleaded guilty on 24 September to leasing bots for spam and denial of service; and Paskalov, sentenced on 12 October to 42 months for a phishing scheme against a Midwest bank (Confirmed [48][49]; allegations where not yet convicted). New Zealand Police, working with FBI Philadelphia, searched the home of a person known as "AKILL", described as the ringleader of a botnet coding group (Confirmed [48][49]). The FBI pages do not name AKILL, and this study does not.

The ransomware ecosystem study follows the later turn of botnet operators toward extortion (Inferred).

Part 3: Estonia, April and May 2007

No other library study covers Estonia 2007, so this study is its home. Every timeline detail below comes from two analyses published by the NATO Cooperative Cyber Defence Centre of Excellence and from press reporting; the first of them says it is not an official NATO position (Reported [40][41]).

What happened

The Bronze Soldier memorial was relocated, amid riots on 26 and 27 April 2007 (Reported [40]). The CCDCOE's "International Cyber Incidents: Legal Considerations" (Tikk, Kaska and Vihul, 2010), whose timeline is sourced to Estonia's State Informatics Centre, records the attacks as running from late on Friday 27 April to Friday 18 May, with some aftermath to the end of May (Reported [40]). It describes two phases. From 27 to 29 April came an emotional phase of manual attacks by nationalistically motivated individuals following ping instructions posted on Russian-language forums. From 30 April to 18 May came a coordinated botnet phase that, in the report's words, "has features of central command and control" (Reported [40]).

The waves the report records are these (Reported [40]):

- **27 April.** DDoS attacks on Estonian government websites begin late in the day.
- **3 May.** The attacks spread to media and private firms.
- **4 May.** A wave of attacks.
- **9 to 11 May.** A wave that included attempts at a "cyber blockade". Hansapank's online banking (also spelled Hansabank) was down for about an hour and a half on 9 May and two hours on 10 May.
- **15 May.** SEB Eesti Uhispank was attacked, and CERT-EE reported a botnet of about 85,000 computers used against government websites.
- **18 to 19 May.** The attacks subside.

The methods were denial of service and distributed denial of service, website defacement, attacks on DNS servers, and mass e-mail and comment spam. The targets were internet infrastructure, the parliament, the president, ministries, political parties, e-banking and news sites. Computers in 178 countries took part (Reported [40]).

Rain Ottis's 2008 CCDCOE paper describes a 22-day campaign that ranged from manually launched pings to botnet DDoS to exploitation of flaws in router software, and says forums discussed pooling resources to rent botnets (Reported [41]).

Attribution and the legal record

On 17 May the BBC reported that Estonia said its websites had been under heavy attack for three weeks, that Prime Minister Ansip directly accused the Russian government, and that Estonia said some attacks were hosted on Russian state servers. Moscow denied involvement, and NATO sent an expert at Estonia's request (Reported [42]). The US-China Economic and Security Review Commission's 2007 report to Congress says denial-of-service attacks were used on a large scale against Estonia in April and May 2007, "allegedly by hackers from Russia" (Confirmed [43]).

Ottis writes that Russia consistently denied direct involvement and that, to his knowledge, the denial is true. He argues that the lack of mitigation and of cooperation amounted to implicit state support; that is his judgement, not a finding (Reported [41]).

The legal record is thin. On 10 May 2007 Estonia's Public Prosecutor's Office sent the Russian Federation a letter rogatory under the 1993 mutual legal assistance agreement, and Russia refused on 28 June 2008, saying the treaty did not provide for the procedure requested (Reported [40]). As of summer 2009 the only person convicted was Dmitri Galushkevich, convicted by Harju County Court on 13 December 2007 according to the judgment CCDCOE cites, an Estonian citizen of Russian ethnicity and an IT student. He admitted ping-flood attacks, made with unidentified others, on the Reform Party's website and intranet between 25 April and 4 May 2007, and was fined 17,500 kroons (about EUR 1,120) plus 5,400 kroons in levies (Reported [40]).

What followed

NATO's cyber defence page says that after the 2007 cyber attacks against Estonia's public and private institutions, Allied defence ministers treated cyber defence as urgent, and that NATO approved its first Policy on Cyber Defence in January 2008 (Confirmed [45]). The NATO page does not call the attacks DDoS and attributes them to no one (Confirmed [45]). The CCDCOE's own history says Estonia proposed the centre in 2004, that it was established on 14 May 2008 with six other nations, and that the 2007 attacks "acted as a wake-up call" to the Alliance (Confirmed [44]).

The ATT&CK data in the library has no group, campaign or software object for Estonia 2007, so the techniques in Part 9 are this study's mapping only (Demonstrated [100]; Inferred). The later Russian record, including the UK's attribution of a 2020 attack on Estonia to GRU Unit 29155, is in Russia-attributed threat actors (Confirmed [98]).

Part 4: the vulnerability record

Office in February

- **Word.** MS07-014 (13 February) fixed four Word vulnerabilities, CVE-2006-5994, CVE-2006-6456, CVE-2006-6561 and CVE-2007-0515. Microsoft says they had been publicly disclosed and that it knew they were being exploited when the bulletin was released (Confirmed [11]).
- **Excel.** MS07-015 (Critical, 13 February) fixed the Excel Malformed Record vulnerability, CVE-2007-0671, which Microsoft knew was being exploited at release. It also re-fixed a PowerPoint flaw, CVE-2006-3877, because the earlier MS06-058 fix had not worked (Confirmed [12]). NVD describes CVE-2007-0671 as user-assisted remote code execution in Excel 2000, XP, 2003 and 2004 for Mac, "as demonstrated by Exploit-MSExcel.h in targeted zero-day attacks", published on 3 February, with NVD-CWE-noinfo and a CVSS v2 score of 9.3. CISA added it to KEV on 12 August 2025 (Confirmed [13][37]).

The Solaris telnet worm

US-CERT's alert TA07-059A of 28 February reports a worm that exploited the Sun Solaris 10 and 11 telnet daemon vulnerability VU#881872 (CVE-2007-0882) to log in as the adm or lp users. The worm installed a backdoor shell, modified crontabs and scanned for other telnet hosts (Confirmed [14]). NVD published the CVE on 12 February, classes it as argument injection, CWE-88, and records no KEV date (Confirmed [15]).

The animated cursor

The Windows animated cursor flaw ran from public report to fix in five days. CERT/CC's VU#191609 gives 29 March as the date it became public and says exploit code was public and the flaw actively exploited (Confirmed [17]). Microsoft's Security Advisory 935423 responded to a public report of attacks; one reading of the advisory gives 29 March as its publication date and another 31 March, and both agree it was updated on 3 April (Confirmed [16]; see Discrepancies). US-CERT's alert TA07-089A of 30 March says the ANI header stack buffer overflow was being actively exploited, and that malicious web pages, HTML e-mail and opening a folder in Windows Explorer could all trigger it (Confirmed [18]).

MS07-017 (Critical, 3 April) fixed seven GDI CVEs, among them CVE-2007-0038, the Animated Cursor remote code execution flaw, which Microsoft rated Critical, publicly disclosed and exploited at release, on Windows 2000 SP4, XP SP2, Server 2003 and Vista (Confirmed [19]). It came out a week before April's monthly release, which makes it an out-of-cycle fix, though the bulletin does not use that term (Inferred [19]). NVD describes a stack-based buffer overflow in the animated cursor code of Windows 2000 SP4 through Vista, published on 30 March, with CWE-119, a CVSS v2 score of 9.3 and no KEV date (Confirmed [20]).

The DNS Server RPC flaw

US-CERT's alert TA07-103A of 13 April reported active exploitation of a stack buffer overflow in the Windows DNS Server RPC management interface (VU#555920, Microsoft advisory 935964) that could give a remote attacker SYSTEM privileges, and said it knew of no complete fix (Confirmed [21][22]). MS07-029 fixed CVE-2007-1748 on 8 May. Microsoft rated it Critical where the DNS Server service runs by default, including on domain controllers, and said it was publicly disclosed and being exploited at release (Confirmed [23]). NVD lists CWE-119 for the flaw in Windows 2000 Server SP4 and Server 2003 SP1 and SP2 (Confirmed [24]).

Apple QuickTime

- **The rtsp:// URI overflow (January).** NVD published CVE-2007-0015, a buffer overflow in QuickTime 7.1.3's handling of rtsp:// URIs, on 1 January 2007 (Confirmed [28]). Any link to a "Month of Apple Bugs" project is not in the NVD record and was not checked.
- **QuickTime for Java (April and May).** CERT/CC's VU#420668 (public date 20 April, note dated 2 May) says an exploit for CVE-2007-2175 was demonstrated at the CanSecWest 2007 conference and that QuickTime 7.1.6 fixed it (Confirmed [25]). NVD describes a flaw in the QuickTime Java extensions (QTJava.dll) as used through browsers with Java enabled, published 24 April, with CWE Other and a CVSS v2 score of 7.6 (Confirmed [27]). The Zero Day Initiative's ZDI-07-023 says the flaw was reported to Apple on 23 April and released in coordination on 1 May, and does not mention CanSecWest (Confirmed [26]). The zero-day market study is the home for the Zero Day Initiative (Confirmed [98]).
- **The RTSP Content-Type overflow (November).** US-CERT's alert TA07-334A of 30 November reported a stack buffer overflow in QuickTime's handling of the RTSP Content-Type header, in QuickTime 7.3 and earlier on Windows and Mac OS X, reachable through web pages in common browsers. Exploit code was first posted publicly on 25 November. NVD records it as CVE-2007-6166, CWE-119, fixed in 7.3.1 (Confirmed [33][105]). The alert does not say the flaw was exploited in attacks (Confirmed [33]).

URI handling and PDF files

US-CERT's alert TA07-297B of 24 October says that on Windows XP and Server 2003 with Internet Explorer 7 installed, a URI-handling flaw (VU#403150) could run commands through a crafted PDF. Public reports said it was being actively exploited with malicious PDF files, and Adobe Reader and Acrobat 8.1.1 mitigated it (Confirmed [29]). NVD's CVE-2007-3896, published 11 October, lists CWE-20 and no KEV date (Confirmed [30]). Microsoft bulletin MS07-061 was not opened. A related NVD record, CVE-2007-5020, covers code execution in Adobe Acrobat and Reader 8.1 on Windows through the mailto: option with IE7 on XP, published 21 September; Adobe's bulletin APSB07-18 could not be opened (Confirmed [31]).

Spoofed FTC e-mail

US-CERT's SA07-303A of 30 October says the FTC reported spoofed e-mail made to look as if it came from the FTC, carrying malicious attachments that could install a keystroke logger or other malicious code (Confirmed [32]).

The KEV tail

CISA's KEV catalog (version 2026.11.10, 1,779 entries) holds exactly three CVE-2007 ids (Confirmed [37]; Demonstrated):

CVE	Product	NVD published	CWE (NVD)	KEV added
CVE-2007-3010	Alcatel OmniPCX Enterprise R7.1 and earlier: remote command execution through shell metacharacters in the Unified Maintenance Tool's masterCGI	18 Sep 2007	NVD-CWE-noinfo and CWE-77 (KEV lists CWE-20)	15 Apr 2022
CVE-2007-5659	Adobe Reader and Acrobat 8.1.1 and earlier: buffer overflows through long arguments to JavaScript methods in a PDF	12 Feb 2008	CWE-120 (KEV lists CWE-119)	8 Jun 2022

CVE	Product	NVD published	CWE (NVD)	KEV added
CVE-2007-0671	Microsoft Excel: Malformed Record remote code execution	3 Feb 2007	NVD-CWE-noinfo	12 Aug 2025

Sources: [34][35][13][37]. CVSS v2 scores in NVD are 10.0, 9.3 and 9.3 (Confirmed [34][35][13]). None of the NVD records checked for the year's other exploited flaws, CVE-2007-0882, CVE-2007-0038, CVE-2007-1748 and CVE-2007-3896, carries a KEV date, nor does the record for CVE-2007-6166, whose exploit code was public (Confirmed [15][20][24][30][105]). KEV's dates say when CISA had evidence of exploitation, not when exploitation began (Inferred).

Other records

NVD published CVE-2007-4559, a directory traversal in Python's tarfile extract and extractall functions (CWE-22), on 28 August 2007 (Confirmed [36]).

The count

Microsoft's 2007 bulletins ran from MS07-001 on 9 January to MS07-069 on 11 December, and MS07-070 has no page (Confirmed [38]). That makes 69 bulletins (Inferred). Of the bulletins opened here, four say a flaw was being exploited at release: MS07-014, MS07-015, MS07-017 and MS07-029 (Confirmed [11][12][19][23]; the count is of bulletins opened, not of all 69). The NVD API returned 2,475 CVE records published between 1 January and 30 April 2007; the full-year count was not obtained because the API rate-limited the requests (Demonstrated [39]).

Part 5: the corporate and data-loss record

TJX (summary)

TJX's Form 8-K, signed on 18 January 2007, reports that on 17 January the company announced an unauthorized intrusion into the systems that process and store customer transaction data for T.J. Maxx, Marshalls, HomeGoods and A.J. Wright in the United States and Puerto Rico and Winners and HomeSense in Canada, with possible exposure at T.K. Maxx in the UK and Ireland and at Bob's Stores (Confirmed [2]). On 21 February TJX said it now believed its systems had also been intruded upon in July 2005 and on later 2005 dates, that card data from US, Puerto Rico and Canadian transactions from January 2003 through June 2004 had been compromised, and that no customer data was compromised after mid-December 2006 (Confirmed [3]).

The 10-K filed on 28 March gives the chronology. TJX found suspicious software on 18 December 2006; the intruder first accessed its systems in July 2005, again later in 2005, and from mid-May 2006 to mid-January 2007 (Confirmed [4]). Card data was stolen in September and November 2005, and the filing's table adds up to about 45.6 million cards: 5.6 million and 25.0 million expired, 3.8 million and 11.2 million unexpired (Confirmed [4]). Personal ID numbers for about 451,000 individuals, from 2003 merchandise returns and in some cases the same as Social Security numbers, were stolen in 2005 (Confirmed [4]). TJX believed the intruder had access to the decryption tool for its encryption software, and that tooling in 2006 could have captured card data, including track 2, sent unencrypted during issuer approval (Confirmed [4]).

The Privacy Commissioner of Canada and Alberta's Information and Privacy Commissioner reported jointly on 25 September (report 2007-389). They put the affected cards at about 45 million across Canada, the US, Puerto Rico, the UK and Ireland, found that TJX had relied on WEP and moved to WPA between October 2005 and mid-January 2007, said the intruder may have entered through wireless networks at US stores, and found that TJX did not meet the safeguard requirements of PIPEDA and Alberta's PIPA (Confirmed [5]).

The settlements followed. TJX and Fifth Third Bancorp signed a settlement with class representatives in In re TJX Companies Retail Security Breach Litigation (D. Mass., MDL 1838) on 21 September, after the US actions were consolidated in April (Confirmed [6]). On 29 November TJX, Visa and Fifth Third Bank settled US Visa issuer claims, with TJX to fund up to $40.9 million in alternative recovery payments under Visa's formula, offered on 6 December with acceptance due by 19 December (Confirmed [7]). The FTC announced its settlement on 27 March 2008, alleging that TJX did not use readily available measures to limit wireless access to its networks, which let an intruder obtain tens of millions of payment cards and personal information on about 455,000 consumers who returned merchandise; the final Decision and Order came on 1 August 2008 (Confirmed [8][9]; allegations). On 5 August 2008 DOJ charged eleven defendants, including Albert "Segvec" Gonzalez, over nine US retailers including TJX, alleging wardriving into wireless networks, sniffer programs on card-processing networks and more than 40 million card numbers stolen (Confirmed [10]; allegations). E-Commerce Threats, section 2.2, is the home for TJX and the Gonzalez ring (Confirmed [97]).

Certegy

Fidelity National Information Services announced on 3 July 2007 that its subsidiary Certegy Check Services had learned that a former employee misappropriated consumer information (Confirmed [50]). The 8-K's item 7.01 gives no record count; the full submission text gives the detail. A senior database administrator sold the data to a data broker, who sold a subset to marketers. About 2.3 million records were involved, about 2.2 million of them with bank account data and 99,000 with card data. There was no outside intrusion, the data left "via physical processes; not electronic transmission", and the Secret Service traced the source (Confirmed [50]).

TD Ameritrade

TD Ameritrade's 10-K for fiscal 2007, filed 26 November, restates its 14 September announcement that it had found and removed unauthorized code giving access to an internal database (Confirmed [51]). The discovery came during an internal investigation of stock-related spam. Client e-mail addresses, names, addresses and phone numbers were retrieved; account numbers, dates of birth and Social Security numbers were stored in the same database, but the company found no evidence they were taken (Confirmed [51]). A class action (Elvey) filed on 31 May had alleged that account holders' e-mail addresses reached spammers, and another followed on 26 September (Confirmed [51]). The filing, as read here, describes no intrusion vector (Inferred [51]).

HMRC's lost discs

On 20 November 2007 the Chancellor told the House of Commons that two password-protected discs holding HMRC's full child benefit data, sent to the National Audit Office by internal post around 18 October, unrecorded and unregistered, were missing. They held records for 25 million individuals and 7.25 million families, including names, addresses, dates of birth, child benefit and National Insurance numbers and bank details where relevant. The Metropolitan Police had been called in, HMRC's chairman Paul Gray had confirmed his intention to resign, and the Information Commissioner was to investigate (Confirmed [53]).

Max Butler (summary)

The Justice Department's Computer Crime and Intellectual Property Section announced that Max Ray Butler ("Iceman") was arrested in San Francisco on 5 September 2007 and indicted in Pittsburgh on 11 September on five wire fraud and identity theft counts. The indictment alleges intrusions into financial institutions and card processing centres from about June 2005 and says he created the CardersMarket carding forum (Confirmed [52]; allegations). Four Books on Cybercrime is the home for the Butler case and its 2010 sentence (Confirmed [98]).

Part 6: the state record

Reported at the time

Every bulleted item below is press reporting of officials' statements. China denied the German, Pentagon and MI5 reports; the Guardian report opened here records no response.

- **Germany (25 August).** Der Spiegel reported that Chinese spy programs had infected computers in the Chancellery and in the economics, research and foreign ministries. The BfV and BSI had found them months earlier, and about 160 GB of outflow was prevented. A confidential BfV assessment said the attacks probably traced to PLA hackers. China's embassy called this speculation without evidence (Reported [54][55]).
- **The Pentagon (June).** The BBC, citing the Financial Times on 4 September, reported US officials as saying the PLA hacked a system of the Defense Secretary's office in June 2007, one of them citing a "high level of confidence". The Pentagon declined to say who it thought was responsible, the network was shut down for more than a week, and the data taken was probably unclassified. China denied it (Reported [56]). The FT article itself could not be opened.
- **The United Kingdom (4 September).** The Guardian reported Whitehall officials as saying Chinese hackers, "some believed to be from the People's Liberation Army", had attacked UK government department networks, including the Foreign Office (Reported [57]).
- **MI5's letter (2 December).** The BBC reported that MI5 had contacted 300 chief executives and security chiefs at banks and financial institutions, warning that Chinese state organisations might be spying on them. A Chinese embassy official denied it. The letter itself was not opened (Reported [58]).

The one official US statement opened here is congressional testimony. The USCC's 2007 report records that on 29 March 2007 General James Cartwright, then commander of US Strategic Command, testified that China was actively conducting cyber reconnaissance by probing the networks of US government agencies and private companies (Confirmed [43]).

Written later: groups that later records date to 2007

None of the reports below was public in 2007. Each dates its own visibility, and most say the activity may have started earlier.

- **APT1.** Mandiant's February 2013 report says APT1 has carried out espionage since at least 2006 and compromised 141 organizations in 20 industries, and assesses, as its own finding, that APT1 is PLA Unit 61398 (Confirmed [60]). For 2007 it records that UglyGorilla wrote the first known MANITSME sample, signed with a date of 06/29/2007, that APT1 has used and modified the BISCUIT backdoor since as early

as 2007, and that the unit's centre building was built in early 2007 (Confirmed [60]). ATT&CK's APT1 (G0006) attributes the group to the 2nd Bureau of the PLA General Staff Department's 3rd Department, Unit 61398, lists the aliases Comment Crew, Comment Group and Comment Panda and 23 technique entries, gives no start date and ties no technique to 2007 (Confirmed [61]). The China-attributed threat actors study and The Hacker and the State are the homes for APT1 (Confirmed [98]).

- **APT5.** ATT&CK's APT5 (G1023) describes a "China-based espionage actor" active since at least 2007, mainly against telecommunications, aerospace and defense in the United States, Europe and Asia (Confirmed [68]). The China-attributed threat actors study is the home (Confirmed [98]).
- **APT28.** FireEye's report of 27 October 2014 says that since at least 2007 APT28 has targeted information on governments, militaries and security organizations, and assesses that it is "most likely sponsored by the Russian government", with a sponsor based in Moscow (Confirmed [66]). ATT&CK's APT28 (G0007) says the group has been active since at least 2004 and attributes it to GRU 85th GTsSS, military unit 26165, so the 2007 date is FireEye's, not ATT&CK's (Confirmed [67]). Russia-attributed threat actors is the home (Confirmed [98]).
- **Darkhotel.** Kaspersky's report of 10 November 2014 refers to "Darkhotel tools dating back to 2007" and names no country (Confirmed [69]). ATT&CK's Darkhotel (G0012) calls it a "suspected South Korean threat group" active since at least 2004; that attribution is ATT&CK's, not Kaspersky's (Confirmed [70]). Other state-attributed actors is the home (Confirmed [98]).
- **Red October.** Kaspersky's report of 14 January 2013 dates the earliest evidence to 2007, possibly May 2007, and describes targets in diplomatic, government and research bodies, mainly in Eastern Europe, the former USSR and Central Asia. It says the operators have "Russian-speaking origins" and makes no nation-state attribution. The spear-phishing it describes used later CVEs, CVE-2009-3129, CVE-2010-3333 and CVE-2012-0158 (Confirmed [71]). Red October is not in the library's ATT&CK data (Demonstrated [100]).
- **Careto (The Mask).** Kaspersky's FAQ of 10 February 2014 says the operation was active from at least 2007, when samples were compiled, until January 2014, with victims at more than 1,000 IP addresses in 31 countries. Kaspersky says it "could be a state-sponsored operation" but calls the Spanish-language clues weak and says false flags are possible (Confirmed [72]). Careto is not in the library's ATT&CK data (Demonstrated [100]).
- **BlackEnergy.** ATT&CK's BlackEnergy (S0089) dates back to at least 2007 and was originally a kit for building DDoS botnets. Criminal and APT actors used it later, including Sandworm Team (G0034) and the 2015 Ukraine Electric Power Attack (C0028); no state use is recorded for 2007 (Confirmed [73]). Sandworm: the operations in the public record is the home for the later use (Confirmed [98]).
- **Flame.** CrySyS's sKyWIper report (v1.05, 31 May 2012) says the Flame main component's filename was first seen in Europe on 5 December 2007, then in the UAE on 28 April 2008 and in Iran on 1 March 2010 (Confirmed [64]). That is a filename sighting, not evidence of an operation on that date (Inferred). ATT&CK's Flame (S0143) says it has been used to collect information since at least 2010, mainly against Middle East targets, and names no actor (Confirmed [65]). United States-attributed threat actors is the home for Flame (Confirmed [98]).

Part 7: industrial systems and critical infrastructure

Stuxnet 0.5 (summary)

Symantec's "Stuxnet 0.5: The Missing Link" (26 February 2013) says this earliest known version was in the wild as early as November 2007 and was submitted to a public scanning service on 15 November 2007. Its command servers were registered on 3 November 2005. It spread only through infected Step 7 projects and carried a valve-closing attack on the Natanz facility. It was set to stop contacting its command servers after 11 January 2009 and to stop spreading on 4 July 2009. Symantec names no actor (Confirmed [62]). ATT&CK's Stuxnet (S0603) says Stuxnet was discovered in 2010 with some components used as early as November 2008, names no actor, and lists ICS techniques including T0873.001 Siemens Project File Format, T0821, T0836, T0843 and T0847. Its earliest date is later than Symantec's because the entry is built on the 1.x analysis (Confirmed [63]). Stuxnet is the home for the whole record, including the 0.5 version (Confirmed [98]).

The Aurora test

CNN reported on 26 September 2007 that a DHS experiment called "Aurora", run in March 2007 at the Department of Energy's Idaho lab, used controlled hacking into a replica power plant control system to make a generator self-destruct. DHS acknowledged the experiment, and DHS's Robert Jamison said "a lot of risk has been taken off the table" (Reported [59]). It was a test on a replica, not an attack, and no primary record of it was opened (Inferred; not checked).

Rules for chemical plants and the grid

DHS issued the Chemical Facility Anti-Terrorism Standards interim final rule on 9 April 2007 (72 FR 17688, effective 8 June). Its risk-based performance standard 8, Cyber, requires deterring cyber sabotage, including unauthorized onsite or remote access to SCADA, DCS, PCS and ICS (Confirmed [76]). On 6 August FERC proposed (RM06-22-000, 72 FR 43970) to approve NERC's eight Critical Infrastructure Protection standards, CIP-002-1 through CIP-009-1, submitted on 28 August 2006, and to direct modifications to protect the Bulk-Power System from cyber attack (Confirmed [77]). The industrial thread continues in Stuxnet, the ICS attacks and advisories study and the ICS ATT&CK Atlas (Inferred).

Part 8: law, standards and the defender view

Law and regulation

- **Identity Theft Task Force (April).** The President's Identity Theft Task Force, created under Executive Order 13402, issued "Combating Identity Theft: A Strategic Plan" in April 2007, covering Social Security number reduction, public and private sector data security and breach response, with a data breach guidance appendix; OMB M-07-16 records its submission on 23 April (Confirmed [74]).
- **OMB M-07-16 (22 May).** "Safeguarding Against and Responding to the Breach of Personally Identifiable Information" required agencies to adopt a breach notification policy within 120 days, to plan the elimination of unnecessary Social Security number use within eighteen months, and to report all incidents involving personal information, potential or confirmed, to US-CERT within one hour of discovery (Confirmed [75]).
- **Minnesota (21 May).** Laws 2007, chapter 108 (Minn. Stat. 325E.64) bars keeping card security codes, PIN verification codes or full magnetic stripe data after authorization (48 hours for PIN debit), effective 1 August 2007, with liability to issuers for breach costs effective 1 August 2008 (Confirmed [78]).

- **Scotland (1 October).** SSI 2007/434, made on 18 September, brought the Police and Justice Act 2006's computer misuse provisions (sections 35 to 38, amending the Computer Misuse Act 1990) into force in Scotland on 1 October, implementing the EU Framework Decision on attacks against information systems of 24 February 2005 (Confirmed [81]).
- **California (14 October).** AB 1298, "Personal information: disclosure", was approved by the Governor and chaptered as Chapter 699, Statutes of 2007. Its content was not checked (Confirmed [79]).
- **Red Flags (9 November).** The OCC, the Federal Reserve, the FDIC, the OTS, the NCUA and the FTC jointly issued the Identity Theft Red Flags and Address Discrepancies final rules under sections 114 and 315 of FACTA (72 FR 63718, effective 1 January 2008), requiring written Identity Theft Prevention Programs (Confirmed [80]).
- **Germany.** Section 202c of the Criminal Code makes it an offence, punishable by up to two years, to prepare an offence under sections 202a or 202b by producing, obtaining, selling or distributing access codes or computer programs whose purpose is such an offence. The current text was opened; its 2007 enactment date was not checked against the federal gazette (Confirmed [82]).

Standards

- **NIST SP 800-94 (20 February).** Guide to Intrusion Detection and Prevention Systems, superseding SP 800-31 (2001). A 2012 draft Revision 1 was retired and never finalized (Confirmed [85]).
- **NIST SP 800-90 (14 March).** The June 2006 SP 800-90, on deterministic random bit generators, is marked withdrawn on 14 March 2007 and superseded by a revision. The CSRC page does not name Dual_EC_DRBG (Confirmed [87]).
- **Dual EC at CRYPTO 2007.** In rump session slides titled "On the Possibility of a Back Door in the NIST SP800-90 Dual Ec Prng", Dan Shumow and Niels Ferguson of Microsoft say explicitly that they are not claiming NIST put in a back door. They show that the generator's prediction resistance depends on solving one instance of the elliptic-curve discrete log problem, and suggest truncating more output bits or generating a random point Q for each instance. The slides carry no date, and the August 2007 date of the session was not checked separately (Confirmed [88]).
- **CAPEC (17 March).** MITRE launched a companion website for CAPEC, funded by DHS under the Software Assurance Strategic Initiative of the National Cyber Security Division and led by Cigital; during the first review period, reading and commenting on the draft required registration (Confirmed [91]). CAPEC's About page says DHS established it and that it was "Initially released in 2007" (Confirmed [93]).
- **CWE drafts.** CWE Draft 6 came on 7 May 2007 and Draft 7 on 1 October, after Draft 5 on 15 December 2006, with difference reports on 6 December 2007. Tool vendors declared CWE compatibility in February and March, 43 organizations were taking part by 17 March, and the CWE-Announce newsletter began on 5 February (Confirmed [91]). CWE version 1.0 came on 9 September 2008 (Confirmed [92]). MITRE posted an updated "Vulnerability Type Distributions in CVE" paper covering 2006 on 26 May, dated 22 May in the text, naming buffer overflows, XSS, SQL injection and PHP file inclusion among the high-level types (Confirmed [91]).
- **RFC 4871 (May).** DomainKeys Identified Mail (DKIM) Signatures, published as a Proposed Standard by Allman, Callas, Delany, Libbey, Fenton and Thomas; later updated by RFC 5672 and obsoleted by RFC 6376 (Confirmed [84]).

- **CVSS v2 (20 June).** FIRST released CVSS version 2, in an announcement datelined Seville (Confirmed [83]).
- **SHA-3 (2 November).** NIST announced the SHA-3 Cryptographic Hash Algorithm Competition (Confirmed [89]).
- **NIST SP 800-38D (28 November).** Galois/Counter Mode (GCM) and GMAC (Confirmed [86]).
- **OWASP Top 10 2007.** A full rewrite, led and sponsored by Aspect Security, which calls itself an education piece, not a standard. It lists A1 Cross Site Scripting, A2 Injection Flaws, A3 Malicious File Execution, A4 Insecure Direct Object Reference, A5 Cross Site Request Forgery, A6 Information Leakage and Improper Error Handling, A7 Broken Authentication and Session Management, A8 Insecure Cryptographic Storage, A9 Insecure Communications and A10 Failure to Restrict URL Access (Confirmed [90]). It gives CWE ids for each category and credits Steve Christey of MITRE with adding them (Confirmed [90]; the ids are in Part 9).
- **Windows Vista and the federal baseline.** Microsoft's lifecycle page gives 25 January 2007 as Vista's start date, with SP1 on 4 February 2008 and extended support ending on 11 April 2017 (Confirmed [94]). NIST's USGCB page says the baseline "evolved from the Federal Desktop Core Configuration mandate" and links XP, Vista and IE7 content, but gives no 2007 dates, and the 2007 OMB memo behind the mandate could not be opened (Confirmed [95]).

The defender view

A flood is an availability incident that needs partners. Hansapank's online banking was down for up to two hours at a time, CERT-EE reported a botnet of about 85,000 computers on 15 May, and computers in 178 countries took part (Reported [40]). The D3FEND Detect and Isolate techniques in Part 9 are the network controls for this class (Inferred).

The exploit came by document and web page. Word, Excel, the animated cursor and the PDF route through a URI flaw were all exploited around release, and the cursor flaw could fire from a web page, HTML e-mail or a folder view (Confirmed [11][12][18][29]). The vulnerability management reference covers prioritizing by exploitation (Inferred).

Server-side services were in play too. The DNS Server RPC flaw ran with SYSTEM privileges on domain controllers, and a worm walked through the Solaris telnet daemon (Confirmed [21][23][14]).

The wireless edge and the card path were the weak points at TJX. WEP, card data sent unencrypted during approval, and an intruder with the decryption tool (Confirmed [5][4]).

Insiders and the post office. Two of the year's large record losses, Certegy and HMRC, needed no hacking at all (the ranking is Inferred; TJX's intrusion was larger) (Confirmed [50][53]). The privacy engineering reference covers data minimization (Inferred).

Part 9: MITRE mappings

No 2007 record opened here carries an ATT&CK id; ATT&CK did not exist. CWE was still in draft and CAPEC had just been released (Confirmed [91][92][93]). Every Enterprise and ICS binding below is this study's later mapping (Inferred), apart from the objects whose ATT&CK entries carry a date that covers 2007: APT5 (G1023), BISCUIT (S0017) and BlackEnergy (S0089) since at least 2007, and APT28 (G0007) and Darkhotel (G0012) since at least 2004 (Confirmed [67][68][70][73]; Demonstrated [100]). Every id was checked against the library's data files and the generated pages under `mitre/`, and nine of the technique ids were also opened on attack.mitre.org (Demonstrated [99][100][103]; Confirmed [96]). Names and tactics are those of ATT&CK v20.0 as the library carries them (Demonstrated [99]).

The Basis column says how strong each tie is, as in the 2016 chronicle. **Listed** means ATT&CK itself lists the id for the object. **Described** means a primary source describes the behavior and this study assigns the id. **Reported** means only a secondary source supports the behavior. **Inferred** means no source describes the behavior in enough detail and the mapping rests on this study's reading.

ATT&CK Enterprise techniques

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1566.001	Spearphishing Attachment	initial-access	Described	Storm's dropper, an e-mail virus (Jan, mass mailing rather than targeted; the attachment form is not in the analysis as verified, so this part is Inferred); spoofed FTC e-mail with malicious attachments (30 Oct)	[1][32]
T1204.002	Malicious File	execution	Described	Excel CVE-2007-0671, user-assisted (3 Feb); crafted PDF files for the URI flaw (24 Oct); FTC-spoofed attachments (30 Oct)	[13][29][32]
T1203	Exploitation for Client Execution	execution	Described	Word (MS07-014) and Excel (MS07-015), exploited at release (13 Feb); animated cursor CVE-2007-0038 (29 Mar to 3 Apr); URI flaw via PDF (24 Oct); CVE-2007-5659 in KEV (exploitation date not stated)	[11][12][18][19][29][35][37]
T1189	Drive-by Compromise	initial-access	Described	Animated cursor flaw triggered by malicious web pages (TA07-089A, 30 Mar)	[18][20]
T1210	Exploitation of Remote Services	lateral-movement	Described	DNS Server RPC flaw exploited (13 Apr to 8 May); Solaris telnet worm (28 Feb)	[21][23][14]
T1190	Exploit Public-Facing Application	initial-access	Inferred	CVE-2007-3010, Alcatel OmniPCX masterCGI, in KEV; neither NVD nor KEV dates the exploitation	[34][37]
T1053.003	Cron	execution, persistence, privilege-escalation	Described	Solaris telnet worm modified crontabs (28 Feb)	[14]
T1046	Network Service Discovery	discovery	Described	Solaris telnet worm scanned for other telnet hosts (28 Feb)	[14]
T1584.005	Botnet	resource-development	Described	Storm's botnets (Jan to Feb); Soloway's spam relayed through botnets (alleged, to May); the Bot Roast cases (Jun, Nov); Estonia (Reported; whether the bots were compromised or rented is not established)	[1][46][47][48][40][41]

Id	Name (ATT&CK v20.0)	Tactic(s)	Basis	Dated event or report	Sources
T1498	Network Denial of Service	impact	Described	Storm floods on anti-spam sites (12 and 30 Jan); Downey's botnet DDoS (Jun); Goldstein's DDoS on a university (1 Nov, alleged); Estonia (27 Apr to 18 May, Reported)	[1][47][48][40]
T1498.001	Direct Network Flood	impact	Described	Storm ICMP floods (Jan); Estonia ping floods, including Galushkevich's admitted attacks (Reported)	[1][40][41]
T1499.001	OS Exhaustion Flood	impact	Described	Storm TCP SYN floods on port 80 (Jan); ATT&CK places SYN floods under this sub-technique, and assigning it here is this study's reading	[1]
T1499.002	Service Exhaustion Flood	impact	Inferred	Estonia: floods against government, e-banking and news web services; the sources do not describe the flood type at the service layer	[40][41]
T1491.002	External Defacement	impact	Reported	Estonia website defacements (CCDCOE)	[40]
T1105	Ingress Tool Transfer	command-and-control	Described	Storm's second-stage download, located through Overnet peers (7 Feb analysis)	[1]
T1669	Wi-Fi Networks	initial-access	Described	TJX: intruder may have entered through store wireless networks (Canadian commissioners, 25 Sep); wardriving into retailers' wireless networks (DOJ, 2008, alleged); FTC alleges wireless access was not limited	[5][10][8]
T1040	Network Sniffing	credential-access, discovery	Described	TJX: 2006 tooling could capture card data sent unencrypted during approval (10-K, 28 Mar); the Gonzalez ring's sniffers (DOJ, 2008, alleged)	[4][10]

Left out on purpose: T1059.004 Unix Shell for the Solaris worm's backdoor shell, because US-CERT does not describe the shell (Confirmed [14]). T1078 Valid Accounts for the worm's logins as adm and lp, because the logins came through argument injection, not through credentials (Confirmed [14][15]; Inferred). T1583.005 Botnet (Acquire Infrastructure) for Estonia, because Ottis records only forum discussion of renting botnets (Reported [41]). Exploitation of router software in Estonia, because Ottis names no product or flaw (Reported [41]). A technique for the TD Ameritrade code, because the filing, as read here, describes no intrusion vector or exfiltration path (Inferred [51]). T1056.001 Keylogging for the spoofed FTC mail, because US-CERT says the attachments "could" install a keystroke logger (Confirmed [32]). Certegy and HMRC, which were an

insider's physical removal and a lost parcel with no ATT&CK technique (Confirmed [50][53]). The QuickTime RTSP flaw, because US-CERT reports public exploit code, not attacks (Confirmed [33]). The 2007 espionage press reports, whose only sources are Reported and describe no technique (Reported [54][56][57][58]).

Techniques ATT&CK lists for APT1, a group later records date to 2007

ATT&CK draws these from later analyses, not from a dated 2007 event, so they are not in this study's Navigator layer (Confirmed [61]; Inferred).

Id	Name (ATT&CK v20.0)	Tactic(s)	Object	Basis	Sources
T1566.002	Spearphishing Link	initial-access	G0006 APT1	Listed (group)	[61]
T1583.001	Domains	resource-development	G0006 APT1	Listed (group)	[61]
T1588.001	Malware	resource-development	G0006 APT1	Listed (group)	[61]
T1003.001	LSASS Memory	credential-access	G0006 APT1	Listed (group)	[61]
T1550.002	Pass the Hash	lateral-movement	G0006 APT1	Listed (group)	[61]

ATT&CK also lists T1566.001 for APT1, which is already in the table above for other 2007 events (Confirmed [61]).

ATT&CK for ICS

Stuxnet 0.5 is the one 2007-dated item in the record opened here that touches an industrial control system. The library has no generated pages for ICS techniques, so the ids are plain text; both are in the library's ICS data (Demonstrated [100]).

Id	Name (ATT&CK for ICS v20.0)	Tactic	Basis	Dated event or report	Sources
T0873	Project File Infection	persistence	Described	Stuxnet 0.5 spread only through infected Step 7 projects; in the wild by November 2007, submitted 15 Nov 2007 (Symantec, 2013)	[62]
T0873.001	Siemens Project File Format	persistence	Described	As above. ATT&CK lists T0873.001 for S0603 from the 1.x analysis, so tying it to the 0.5 version is this study's reading	[62][63]

Left out: the valve-closing attack that Stuxnet 0.5 carried, because Symantec says whether it succeeded is unknown and dates no use of it to 2007 (Confirmed [62]; Stuxnet covers it). The Aurora test, which was a test on a replica reported by CNN (Reported [59]). The other ICS techniques ATT&CK lists for S0603 (T0821 Modify Controller Tasking, T0836 Modify Parameter, T0843 Program Download, T0847 Replication Through Removable Media) come from the 1.x analysis and are not tied to 2007 (Confirmed [63]).

ATT&CK groups, software and campaigns

Object	Id	Binding	Sources
APT1	G0006	Bound with a caveat: Mandiant dates a MANITSME sample and BISCUIT use to 2007; ATT&CK gives no start year; the Unit 61398 attribution is Mandiant's and ATT&CK's assessment	[60][61]
BISCUIT	S0017	Bound with a caveat: Mandiant and ATT&CK's S0017 entry both say APT1 has used it since as early as 2007; no 2007 sample is named	[60][100]
APT28	G0007	Bound with a caveat: FireEye dates its activity to at least 2007; ATT&CK says at least 2004	[66][67]
APT5	G1023	Bound: ATT&CK says active since at least 2007	[68]
Darkhotel	G0012	Bound with a caveat: Kaspersky dates its tools to 2007; ATT&CK says at least 2004	[69][70]
Stuxnet	S0603	Bound with a caveat: Symantec dates the 0.5 version to November 2007; ATT&CK's entry starts in 2008 from the 1.x analysis	[62][63]
BlackEnergy	S0089	Bound with a caveat: ATT&CK dates it to at least 2007 as a DDoS botnet kit; no 2007 operation is named	[73]
Flame	S0143	Not bound to 2007: a filename sighting only; ATT&CK dates use to 2010	[64][65]
Sandworm Team; 2015 Ukraine Electric Power Attack	G0034; C0028	Not bound to 2007: later users of BlackEnergy, linked for context	[73]

No campaign object is bound: the library's campaign data has none first seen between 2005 and 2008 (Demonstrated [100]). The library's software and group data has no object for Storm (Peacomm, Nuwar), MANITSME, Red October or Careto, and none for the Estonia attacks (Demonstrated [100]). The ATT&CK APT5 page counts 32 technique entries, while the library's group data gives 29; this study binds no APT5 technique to 2007, so the difference does not change the layer (Confirmed [68]; Demonstrated [100]).

CWE and CAPEC

Rows marked NVD carry the CWE NVD lists; others are this study's classes (Inferred). Names are those in the library's CWE and CAPEC data, and every CAPEC listed has a page under `/mitre/capec/` (Demonstrated [101][103]). The library has no per-CWE generated pages, so CWE ids are plain text; the CWE reference is the library's entry point. The CAPEC column uses the CAPEC ids the library's CWE data relates to each weakness, unless marked as this study's pairing (Demonstrated [101]).

CWE	Weakness (library name)	Basis	2007 record	CAPEC
CWE-88	Improper Neutralization of Argument Delimiters in a Command	NVD	Solaris in.telnetd (CVE-2007-0882)	CAPEC-137 Parameter Injection; CAPEC-88 OS Command Injection

CWE	Weakness (library name)	Basis	2007 record	CAPEC
CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	NVD	Animated cursor (CVE-2007-0038) [20]; DNS Server RPC (CVE-2007-1748) [24]; QuickTime RTSP (CVE-2007-6166) [105]	CAPEC-100 Overflow Buffers; CAPEC-8 Buffer Overflow in an API Call; CAPEC-14 Client-side Injection-induced Buffer Overflow (the client-side flaws)
CWE-121	Stack-based Buffer Overflow	Study's class	The animated cursor and DNS RPC flaws, which US-CERT describes as stack buffer overflows	CAPEC-100 Overflow Buffers (study's pairing; the library relates no CAPEC to CWE-121)
CWE-120	Buffer Copy without Checking Size of Input	NVD	Adobe Reader JavaScript methods (CVE-2007-5659)	CAPEC-100 Overflow Buffers; CAPEC-14 Client-side Injection-induced Buffer Overflow
CWE-20	Improper Input Validation	NVD	Windows URI handling (CVE-2007-3896); KEV's entry for CVE-2007-3010	None assigned (the library relates dozens; none is specific to these flaws)
CWE-77	Improper Neutralization of Special Elements used in a Command	NVD (with NVD-CWE-noinfo)	Alcatel OmniPCX masterCGI (CVE-2007-3010)	None assigned
NVD-CWE-noinfo	(as NVD lists it)	NVD	Excel Malformed Record (CVE-2007-0671)	None assigned
NVD-CWE-Other	(as NVD lists it)	NVD	QuickTime for Java (CVE-2007-2175)	None assigned
CWE-22	Improper Limitation of a Pathname to a Restricted Directory	NVD	Python tarfile (CVE-2007-4559)	CAPEC-126 Path Traversal
CWE-79	Improper Neutralization of Input During Web Page Generation	OWASP 2007	A1 Cross Site Scripting	CAPEC-63 Cross-Site Scripting (XSS)
CWE-89	Improper Neutralization of Special Elements used in an SQL Command	OWASP 2007	A2 Injection Flaws (with CWE-77, CWE-90, CWE-91 and CWE-93)	CAPEC-66 SQL Injection
CWE-98	Improper Control of Filename for Include/Require Statement in PHP Program	OWASP 2007	A3 Malicious File Execution (with CWE-78, CWE-95 and CWE-434)	CAPEC-193 PHP Remote File Inclusion
CWE-352	Cross-Site Request Forgery	OWASP 2007	A5 Cross Site Request Forgery	CAPEC-62 Cross Site Request Forgery

CWE	Weakness (library name)	Basis	2007 record	CAPEC
CWE-311	Missing Encryption of Sensitive Data	OWASP 2007; study's class for TJX	A8 and A9 (with CWE-326, CWE-321 and CWE-325); TJX card data sent unencrypted during approval	CAPEC-157 Sniffing Attacks; CAPEC-158 Sniffing Network Traffic (the library also lists CAPEC-158 on T1040)
none bound	(phishing)	Library data	Storm's e-mail; spoofed FTC e-mail	CAPEC-163 Spear Phishing (the library lists it on T1566.001); CAPEC-98 Phishing
none bound	(flooding)	Library data	Storm floods; Estonia; the Bot Roast DDoS cases	CAPEC-125 Flooding (the library lists it on T1498.001 and T1499); CAPEC-482 TCP Flood (on T1498.001, T1499.001 and T1499.002)
none bound	(scanning)	Library data	Solaris worm scanning for telnet hosts	CAPEC-300 Port Scanning (the library lists it on T1046)

The OWASP Top 10 2007 also gives CWE-472 (A4), CWE-200, CWE-203, CWE-215 and CWE-209 (A6), CWE-287 and CWE-522 (A7), and CWE-288 and CWE-285 (A10) (Confirmed [90]). NVD assigned its CWE ids after the fact: CWE was in draft for all of 2007 (Confirmed [91][92]; Inferred for the assignment dates).

D3FEND countermeasures

The technique-to-countermeasure links come from the library's D3FEND data; pairing them with the 2007 record is this study's reading (Demonstrated [102]; Inferred). Every page exists under `/mitre/d3fend/` (Demonstrated [103]).

Technique from the record	D3FEND countermeasures (D3FEND tactic)	2007 analogue
T1203, T1210	Process Segment Execution Prevention (Harden); Segment Address Offset Randomization (Harden); Stack Frame Canary Validation (Harden)	The stack overflows in the animated cursor and DNS RPC code [18][21]; no 2007 source opened here names these controls (Inferred)
T1189	URL Reputation Analysis (Detect); Network Traffic Filtering (Isolate)	Malicious web pages carrying the animated cursor exploit [18]
T1566.001	Email Filtering (Isolate); Sender Reputation Analysis (Detect); File Analysis (Detect)	Storm's mail and the spoofed FTC mail [1][32]; DKIM, RFC 4871, is the sender-authentication analogue, and Message Authentication is its D3FEND class, a pairing the library's data does not make for T1566.001 (Inferred) [84]
T1204.002	Executable Allowlisting (Isolate); File Analysis (Detect)	Malicious Office and PDF files [12][29]
T1210	Connection Attempt Analysis (Detect); Network Traffic Signature Analysis (Detect)	The Solaris worm's scanning for telnet hosts [14]; the IDPS class NIST described in SP 800-94 [85] (Inferred)

Technique from the record	D3FEND countermeasures (D3FEND tactic)	2007 analogue
T1498.001, T1499.002	Inbound Session Volume Analysis (Detect); Inbound Traffic Filtering (Isolate); Network Traffic Filtering (Isolate)	Storm's floods and the Estonia waves [1][40]
T1190	Database Query String Analysis (Detect); Inbound Traffic Filtering (Isolate)	OWASP's A2 Injection Flaws [90] (Inferred)
T1105	Outbound Traffic Filtering (Isolate); Network Traffic Signature Analysis (Detect)	Storm's second-stage download [1]
T0873 (ICS)	Software Update (Harden); Message Authentication (Harden)	Stuxnet 0.5's infected Step 7 projects [62] (Inferred)

The library links T1584.005, T1498 (the parent), T1499.001, T1053.003, T1046 and T1669 to no D3FEND countermeasure, T1040 only to DNS Traffic Analysis, and T1491.002 only to Decoy Network Resource and Network Resource Access Mediation; none of these has a 2007 analogue here (Demonstrated [102]). ATT&CK mitigation pages exist for M1051 Update Software, M1050 Exploit Protection, M1042 Disable or Remove Feature or Program, M1037 Filter Network Traffic, M1031 Network Intrusion Prevention, M1030 Network Segmentation, M1041 Encrypt Sensitive Information, M1049 Antivirus/Antimalware and M1017 User Training (Demonstrated [103]). Disabling the Solaris telnet service maps most closely to M1042, TJX's unencrypted card path to M1041 and the floods to M1037 (Inferred [14][4][1][40]).

Navigator layers

The study's Enterprise techniques are saved as one ATT&CK Navigator layer pinned to ATT&CK v20, navigator/library-layers/chronicle-2007.json, in the format of the existing chronicle layers: domain enterprise-attack, navigator 4.9, layer 4.5, described as a curated case-study layer and not an official MITRE mapping (Demonstrated [104]). It lists the 17 techniques in the Enterprise table under each tactic they carry in v20.0, 20 technique-tactic entries in all, and is listed on the Navigator layers page. The five techniques in the APT1 table are not in it. Scores show the basis, not severity, in the house scale set by the 2016 chronicle: 100 where the source or ATT&CK object prints the id, 70 where a primary source describes the behavior and this study assigns the id, 50 where only a Reported source supports it, and 40 for an Inferred mapping (Demonstrated [104]). No 2007 source prints an ATT&CK id, so no technique scores 100 (Inferred). T1491.002 scores 50; T1190 and T1499.002 score 40; every other row scores 70. Each entry's comment names the source numbers in the Sources table below.

The two ICS rows are saved as an ATT&CK for ICS layer, navigator/case-studies/chronicle-2007-ics.json, where the library keeps the other chronicle ICS layers, with domain ics-attack and both techniques at 70 under the persistence tactic (Demonstrated [104]).

Cross-cutting themes

Crime built infrastructure. Storm's peer-to-peer lookups, Soloway's botnet-relayed spam, bots leased for spam and DDoS, and the million victim computers Bot Roast found show criminals building and leasing botnet capacity (Confirmed [1][46][47][48]; 'as a service' is Inferred from the Sweaney case [48]).

A flood became a political event. Estonia's three weeks of DDoS drew a prime minister's accusation, a NATO expert, a refused legal request and, by January 2008, NATO's first cyber defence policy (Reported [40][42]; Confirmed [45]).

The document and the browser plug-in were the way in. Office files, PDFs, an animated cursor and QuickTime all carried exploitable flaws, several exploited before fixes (Confirmed [11][12][18][29][33]).

Large losses came through weak edges, not only exploits. TJX's intruder may have entered through store wireless networks and had access to TJX's decryption tool, Certegy's administrator walked data out, and HMRC's discs were lost in the post (Confirmed [5][4][50][53]).

The espionage record has two layers. In 2007 there were press reports quoting officials, mostly denied by China; from 2012 to 2014 vendors dated APT1, APT28, Darkhotel, Red October and Careto activity to the year, mostly without naming a state (Reported [54][56][57][58]; Confirmed [60][66][69][71][72]).

The rules arrived in a cluster. M-07-16, the Red Flags rule, CFATS's cyber standard, the FERC CIP proposal, Minnesota's card-data law, CVSS v2, DKIM, the OWASP Top 10 2007 and CAPEC all date from 2007 (Confirmed [75][80][76][77][78][83][84][90][93]).

What is overstated and what is understated

This section is the study's reading of the record (Inferred).

- **Overstated: Storm's size.** Press figures in the millions circulate, but the one primary opened here gives no size, so this study states none [1].
- **Overstated: "Estonia was the first cyberwar".** The record shows three weeks of DDoS, defacement and DNS attacks, one local conviction with a fine of about EUR 1,120, and a state attribution that Estonia's prime minister made and no court tested. NATO's own page attributes nothing [40][42][45].
- **Overstated: "the PLA hacked the Pentagon and the Chancellery".** These rest on unnamed or confidential official assessments relayed by the FT, the BBC, the Guardian and Der Spiegel, and China denied the German and Pentagon reports [54][56][57].
- **Overstated: "a Dual_EC backdoor was found in 2007".** The 2007 slides explicitly decline to say that NIST put in a back door; they describe a possibility and suggest fixes [88].
- **Overstated: Aurora as an attack.** It was a lab test on a replica, and the 2007 public record opened here is a news report with DHS's acknowledgement [59].
- **Overstated: the precision of ids on 2007 events.** Every ATT&CK and CAPEC id here is retrospective, CWE was a draft, and KEV came 15 to 18 years later [91][92][37].
- **Understated: the standards plumbing.** CVSS v2, DKIM, SP 800-94, GCM, the SHA-3 competition, CAPEC's public start and the CWE drafts with vendor compatibility get a line each, yet later work runs on them [83][84][85][86][89][91][93].
- **Understated: the KEV tail.** Two CVE-2007 ids entered KEV in 2022 and one in 2025 [37].

- **Understated: the web-application weakness classes.** XSS, injection and PHP file inclusion led the 2007 OWASP list and MITRE's CVE distribution paper while card-theft cases drew the headlines [90][91].
- **Understated: insider and paper-path losses.** Two of the year's largest record losses, Certegy's 2.3 million records and HMRC's 25 million individuals, involved no network intrusion [50][53].
- **Understated: 2007 as a regulatory year.** M-07-16's one-hour rule, the Red Flags rule, CFATS's cyber standard and the FERC CIP proposal set obligations that later regimes built on [75][80][76][77].
- **Understated: espionage already under way.** APT1, APT5, APT28, Red October, Careto, Darkhotel tools and Stuxnet 0.5 were all active in 2007 by later accounts, and none was public at the time [60][68][66][71][72][69][62].

Discrepancies in the record

- **Advisory 935423's date.** Read once as published 29 March and once as 31 March; both readings agree on the 3 April update, and CERT/CC gives 29 March as the date the flaw became public [16][17].
- **Estonia's end date and length.** 18 May with aftermath to end of May (Tikk and colleagues), "subsiding by 19 May" in the same report's timeline, and a 22-day campaign in Ottis [40][41].
- **Galushkevich's dates.** He admitted attacks from 25 April, two days before the timeline's 27 April start [40].
- **Hansapank's spelling and outage.** Hansabank's internet channels disturbed on 10 May in one reading of the timeline; outages of about 1.5 hours on 9 May and 2 hours on 10 May at Hansapank, the largest commercial bank, in the report's narrative [40].
- **TJX's card total.** About 45.6 million from the 10-K table, about 45 million from the Canadian commissioners, and more than 40 million in DOJ's charges against the whole ring [4][5][10].
- **TJX's return-customer total.** About 451,000 in the 10-K and about 455,000 in the FTC release [4][8].
- **Certegy's count.** The 8-K's item 7.01 gives no record count; the full submission text gives about 2.3 million [50].
- **APT28's start.** 2007 per FireEye; 2004 per ATT&CK [66][67].
- **Darkhotel's start.** Tools from 2007 per Kaspersky; active since 2004 per ATT&CK, which also adds the South Korea attribution [69][70].
- **Stuxnet's start.** In the wild by November 2007 per Symantec; components from November 2008 per ATT&CK [62][63].
- **APT5's technique count.** 32 entries on the ATT&CK page; 29 in the library's group data [68][100].
- **QuickTime for Java and CanSecWest.** CERT/CC says the exploit was demonstrated at CanSecWest 2007; ZDI's advisory does not mention the conference [25][26].
- **Storm's grade.** SecureWorks' technical findings are graded Confirmed as the vendor's own analysis; its reading that the Spamhaus attack was an accident is graded Reported [1].
- **CVE-2007-3010's weakness.** NVD lists NVD-CWE-noinfo and CWE-77; KEV lists CWE-20 [34][37].

Sources

Sources were opened on 12 November 2026, and the library data checks were run on 13 November 2026 as the Opened column shows. All are checked as of 13 November 2026. Grade is the source's evidence grade as used in this study. Addresses shown as code rather than as links refuse automated link checkers (the sec.gov filings, the ftc.gov pages, the NVD API queries and the Sophos research page); copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	SecureWorks Counter Threat Unit (Joe Stewart), Storm Worm DDoS analysis, 7 Feb 2007 (now hosted by Sophos)	`https://www.sophos.com/en-us/research/storm-worm`	2026-11-12	Confirmed (vendor's own analysis); Reported (the Spamhaus reading)
2	The TJX Companies, Form 8-K signed 18 Jan 2007 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/109198/000095013507000226/b63779txe8vk.htm` ; `https://www.sec.gov/Archives/edgar/data/109198/000095013507000226/0000950135-07-000226.txt`	2026-11-12	Confirmed
3	The TJX Companies, Form 8-K update, 21 Feb 2007 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/109198/000115752307001830/0001157523-07-001830.txt`	2026-11-12	Confirmed
4	The TJX Companies, Form 10-K for fiscal 2007, filed 28 Mar 2007 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/109198/000095013507001906/b64407tje10vk.htm`	2026-11-12	Confirmed
5	Privacy Commissioner of Canada and Alberta OIPC, report of investigation 2007-389 (TJX and Winners), 25 Sep 2007	https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2007/tjx_rep_070925/	2026-11-12	Confirmed
6	The TJX Companies, Form 8-K on the class settlement, Sep 2007 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/109198/000095013507005786/0000950135-07-005786.txt`	2026-11-12	Confirmed
7	The TJX Companies, Form 8-K on the Visa settlement, filed 30 Nov 2007 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/109198/000095013507007247/0000950135-07-007247.txt`	2026-11-12	Confirmed
8	FTC, settlement announcement in separate actions against TJX and against Reed Elsevier and Seisint, 27 Mar 2008	`https://www.ftc.gov/news-events/news/press-releases/2008/03/agency-announces-settlement-separate-actions-against-retailer-tjx-data-brokers-reed-elsevier-seisint`	2026-11-12	Confirmed (as alleged)
9	FTC, matter 072-3055, The TJX Companies	`https://www.ftc.gov/legal-library/browse/cases-proceedings/072-3055-tjx-companies-inc-matter`	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
10	DOJ, release 08-689, charges against Albert Gonzalez and ten others, 5 Aug 2008	https://www.justice.gov/archive/opa/pr/2008/August/08-ag-689.html	2026-11-12	Confirmed (as alleged); Inferred (the technique mapping)
11	Microsoft Security Bulletin MS07-014	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2007/ms07-014	2026-11-12	Confirmed
12	Microsoft Security Bulletin MS07-015	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2007/ms07-015	2026-11-12	Confirmed
13	NVD, CVE-2007-0671	https://nvd.nist.gov/vuln/detail/CVE-2007-0671	2026-11-12	Confirmed
14	US-CERT, TA07-059A, Sun Solaris Telnet Worm, 28 Feb 2007 (CISA archive)	https://www.cisa.gov/news-events/alerts/2007/02/28/sun-solaris-telnet-worm	2026-11-12	Confirmed; Inferred (the technique mapping)
15	NVD API, CVE-2007-0882	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2007-0882`	2026-11-12	Confirmed
16	Microsoft Security Advisory 935423 (animated cursor)	https://learn.microsoft.com/en-us/security-updates/securityadvisories/2007/935423	2026-11-12	Confirmed
17	CERT/CC, VU#191609 (animated cursor)	https://www.kb.cert.org/vuls/id/191609	2026-11-12	Confirmed
18	US-CERT, TA07-089A, Microsoft Windows ANI Header Stack Buffer Overflow, 30 Mar 2007 (CISA archive)	https://www.cisa.gov/news-events/alerts/2007/03/30/microsoft-windows-ani-header-stack-buffer-overflow	2026-11-12	Confirmed
19	Microsoft Security Bulletin MS07-017	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2007/ms07-017	2026-11-12	Confirmed; Inferred (out of cycle)
20	NVD, CVE-2007-0038 (record and API)	https://nvd.nist.gov/vuln/detail/CVE-2007-0038 ; `https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2007-0038`	2026-11-12	Confirmed
21	US-CERT, TA07-103A, Microsoft Windows DNS RPC Buffer Overflow, 13 Apr 2007 (CISA archive)	https://www.cisa.gov/news-events/alerts/2007/04/13/microsoft-windows-dns-rpc-buffer-overflow	2026-11-12	Confirmed
22	CERT/CC, VU#555920 (DNS RPC)	https://www.kb.cert.org/vuls/id/555920	2026-11-12	Confirmed
23	Microsoft Security Bulletin MS07-029	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2007/ms07-029	2026-11-12	Confirmed
24	NVD, CVE-2007-1748	https://nvd.nist.gov/vuln/detail/CVE-2007-1748	2026-11-12	Confirmed
25	CERT/CC, VU#420668 (QuickTime for Java)	https://kb.cert.org/vuls/id/420668	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
26	Zero Day Initiative, ZDI-07-023	https://www.zerodayinitiative.com/advisories/ZDI-07-023/	2026-11-12	Confirmed
27	NVD, CVE-2007-2175	https://nvd.nist.gov/vuln/detail/CVE-2007-2175	2026-11-12	Confirmed
28	NVD, CVE-2007-0015	https://nvd.nist.gov/vuln/detail/CVE-2007-0015	2026-11-12	Confirmed
29	US-CERT, TA07-297B, Adobe Updates for Microsoft Windows URI Vulnerability, 24 Oct 2007 (CISA archive)	https://www.cisa.gov/news-events/alerts/2007/10/24/adobe-updates-microsoft-windows-uri-vulnerability	2026-11-12	Confirmed
30	NVD API, CVE-2007-3896	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2007-3896`	2026-11-12	Confirmed
31	NVD, CVE-2007-5020	https://nvd.nist.gov/vuln/detail/CVE-2007-5020	2026-11-12	Confirmed
32	US-CERT, SA07-303A, Federal Trade Commission Reports Spoofed Email, 30 Oct 2007 (CISA archive)	https://www.cisa.gov/news-events/alerts/2007/10/30/federal-trade-commission-reports-spoofed-email	2026-11-12	Confirmed
33	US-CERT, TA07-334A, Apple QuickTime RTSP Buffer Overflow, 30 Nov 2007 (CISA archive)	https://www.cisa.gov/news-events/alerts/2007/11/30/apple-quicktime-rtsp-buffer-overflow	2026-11-12	Confirmed
34	NVD, CVE-2007-3010	https://nvd.nist.gov/vuln/detail/CVE-2007-3010	2026-11-12	Confirmed
35	NVD, CVE-2007-5659	https://nvd.nist.gov/vuln/detail/CVE-2007-5659	2026-11-12	Confirmed
36	NVD, CVE-2007-4559	https://nvd.nist.gov/vuln/detail/CVE-2007-4559	2026-11-12	Confirmed
37	CISA, Known Exploited Vulnerabilities catalog (JSON, version 2026.11.10)	https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-12	Confirmed; Demonstrated (the CVE-2007 count)
38	Microsoft Security Bulletins MS07-001 and MS07-069	https://learn.microsoft.com/en-us/security-updates/securitybulletins/2007/ms07-001 ; https://learn.microsoft.com/en-us/security-updates/securitybulletins/2007/ms07-069	2026-11-12	Confirmed; Inferred (the bulletin count)
39	NVD CVE API 2.0, records published 1 Jan to 30 Apr 2007	`https://services.nvd.nist.gov/rest/json/cves/2.0?pubStartDate=2007-01-01T00:00:00.000&pubEndDate=2007-04-30T23:59:59.999&resultsPerPage=1`	2026-11-12	Demonstrated
40	CCDCOE, Tikk, Kaska and Vihul, "International Cyber Incidents: Legal Considerations", 2010	https://ccdcoe.org/uploads/2018/10/legalconsiderations_0.pdf	2026-11-12	Reported

#	Source	URL	Opened	Grade
41	CCDCOE, Rain Ottis, "Analysis of the 2007 Cyber Attacks Against Estonia from the Information Warfare Perspective", 2008	https://ccdcoe.org/uploads/2018/10/Ottis2008_AnalysisOf2007FromTheInformationWarfarePerspective.pdf	2026-11-12	Reported
42	BBC News, Estonia attacks, 17 May 2007	http://news.bbc.co.uk/2/hi/europe/6665145.stm	2026-11-12	Reported
43	US-China Economic and Security Review Commission, 2007 Report to Congress	https://www.uscc.gov/sites/default/files/annual_reports/2007-Report-to-Congress.pdf	2026-11-12	Confirmed
44	CCDCOE, About us	https://ccdcoe.org/about-us/	2026-11-12	Confirmed
45	NATO, Cyber defence (topic page)	https://www.nato.int/cps/en/natohq/topics_78170.htm	2026-11-12	Confirmed
46	US Attorney, Western District of Washington, Soloway arrest, 30 May 2007	https://www.justice.gov/archive/usao/waw/press/2007/may/soloway.html	2026-11-12	Confirmed (as alleged)
47	FBI, "Over 1 Million Potential Victims of Botnet Cyber Crime" (Operation Bot Roast), 13 Jun 2007	https://archives.fbi.gov/archives/news/pressrel/press-releases/over-1-million-potential-victims-of-botnet-cyber-crime	2026-11-12	Confirmed (as alleged for the charges)
48	FBI, "Bot Roast II Nets 8 Individuals", 29 Nov 2007	https://archives.fbi.gov/archives/news/pressrel/press-releases/bot-roast-ii-nets-8-individuals	2026-11-12	Confirmed
49	FBI, news story on Bot Roast II, 29 Nov 2007	https://archives.fbi.gov/archives/news/stories/2007/november/botnet_112907	2026-11-12	Confirmed
50	Fidelity National Information Services, Form 8-K on Certegy, Jul 2007 (SEC EDGAR; filing and full submission text)	`https://www.sec.gov/Archives/edgar/data/1136893/000089256907000900/a31648e8vk.htm` ; `https://www.sec.gov/Archives/edgar/data/1136893/000089256907000900/0000892569-07-000900.txt`	2026-11-12	Confirmed
51	TD Ameritrade Holding, Form 10-K for fiscal 2007, filed 26 Nov 2007 (SEC EDGAR)	`https://www.sec.gov/Archives/edgar/data/1173431/000095013707017708/c21738e10vk.htm`	2026-11-12	Confirmed
52	DOJ CCIPS, Butler indictment, 11 Sep 2007	https://www.justice.gov/archive/criminal/cybercrime/press-releases/2007/butlerIndict.htm	2026-11-12	Confirmed (as alleged)
53	UK Parliament, House of Commons Hansard, 20 Nov 2007 (HMRC data loss statement)	https://publications.parliament.uk/pa/cm200708/cmhansrd/cm071120/debtext/71120-0004.htm	2026-11-12	Confirmed
54	Der Spiegel, "Computerspionage: Chinesische Trojaner auf PCs im Kanzleramt", 25 Aug 2007	https://www.spiegel.de/netzwelt/tech/computerspionage-chinesische-trojaner-auf-pcs-im-kanzleramt-a-501954.html	2026-11-12	Reported

#	Source	URL	Opened	Grade
55	Der Spiegel International, the same report in English	https://www.spiegel.de/international/world/chinese-hackers-targeted-german-ministries-a-501954.html	2026-11-12	Reported
56	BBC News, Pentagon hacking report, 4 Sep 2007	http://news.bbc.co.uk/2/hi/americas/6977533.stm	2026-11-12	Reported
57	The Guardian, Chinese hackers and UK government networks, 4 Sep 2007	https://www.theguardian.com/technology/2007/sep/04/news.internet	2026-11-12	Reported
58	BBC News, MI5 warning to firms, 2 Dec 2007	http://news.bbc.co.uk/2/hi/business/7123970.stm	2026-11-12	Reported
59	CNN, Aurora generator test report, 26 Sep 2007	http://www.cnn.com/2007/US/09/26/power.at.risk/index.html	2026-11-12	Reported
60	Mandiant, "APT1: Exposing One of China's Cyber Espionage Units", Feb 2013	https://services.google.com/fh/files/misc/mandiant-apt1-report.pdf	2026-11-12	Confirmed (vendor's assessment)
61	MITRE ATT&CK, APT1 (G0006)	https://attack.mitre.org/groups/G0006/	2026-11-12	Confirmed
62	Symantec, "Stuxnet 0.5: The Missing Link", 26 Feb 2013	https://docs.broadcom.com/doc/stuxnet-missing-link-13-en	2026-11-12	Confirmed; Inferred (the ICS mapping)
63	MITRE ATT&CK, Stuxnet (S0603)	https://attack.mitre.org/software/S0603/	2026-11-12	Confirmed
64	CrySyS Lab, sKyWIper (Flame) technical report v1.05, 31 May 2012	https://static.crysys.hu/publications/files/skywiper.pdf	2026-11-12	Confirmed
65	MITRE ATT&CK, Flame (S0143)	https://attack.mitre.org/software/S0143/	2026-11-12	Confirmed
66	FireEye, "APT28: A Window into Russia's Cyber Espionage Operations?", 27 Oct 2014	https://cloud.google.com/blog/topics/threat-intelligence/apt28-a-window-into-russias-cyber-espionage-operations	2026-11-12	Confirmed (vendor's assessment)
67	MITRE ATT&CK, APT28 (G0007)	https://attack.mitre.org/groups/G0007/	2026-11-12	Confirmed
68	MITRE ATT&CK, APT5 (G1023)	https://attack.mitre.org/groups/G1023/	2026-11-12	Confirmed
69	Kaspersky, "The Darkhotel APT", 10 Nov 2014	https://securelist.com/the-darkhotel-apt/66779/	2026-11-12	Confirmed
70	MITRE ATT&CK, Darkhotel (G0012)	https://attack.mitre.org/groups/G0012/	2026-11-12	Confirmed
71	Kaspersky, Red October investigation, 14 Jan 2013	https://securelist.com/red-october-diplomatic-cyber-attacks-investigation/36740/	2026-11-12	Confirmed
72	Kaspersky, "The Careto/Mask APT: Frequently Asked Questions", 10 Feb 2014	https://securelist.com/the-caretomask-apt-frequently-asked-questions/58254/	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
73	MITRE ATT&CK, BlackEnergy (S0089)	https://attack.mitre.org/software/S0089/	2026-11-12	Confirmed
74	President's Identity Theft Task Force, "Combating Identity Theft: A Strategic Plan", Apr 2007	https://www.ftc.gov/sites/default/files/documents/reports/combating-identity-theft-strategic-plan/strategicplan.pdf	2026-11-12	Confirmed
75	OMB, M-07-16, Safeguarding Against and Responding to the Breach of Personally Identifiable Information, 22 May 2007	https://georgewbush-whitehouse.archives.gov/omb/memoranda/fy2007/m07-16.pdf	2026-11-12	Confirmed
76	Federal Register, Chemical Facility Anti-Terrorism Standards, 9 Apr 2007	https://www.federalregister.gov/documents/2007/04/09/E7-6363/chemical-facility-anti-terrorism-standards	2026-11-12	Confirmed
77	Federal Register, Mandatory Reliability Standards for Critical Infrastructure Protection (NOPR), 6 Aug 2007	https://www.federalregister.gov/documents/2007/08/06/E7-14710/mandatory-reliability-standards-for-critical-infrastructure-protection	2026-11-12	Confirmed
78	Minnesota Revisor of Statutes, Laws 2007, chapter 108	https://www.revisor.mn.gov/laws/2007/0/108/	2026-11-12	Confirmed
79	California Legislative Information, AB 1298 (2007 to 2008) bill history	https://leginfo.legislature.ca.gov/faces/billHistoryClient.xhtml?bill_id=200720080AB1298	2026-11-12	Confirmed
80	Federal Register, Identity Theft Red Flags and Address Discrepancies, 9 Nov 2007	https://www.federalregister.gov/documents/2007/11/09/07-5453/identity-theft-red-flags-and-address-discrepancies-under-the-fair-and-accurate-credit-transactions	2026-11-12	Confirmed
81	legislation.gov.uk, SSI 2007/434	https://www.legislation.gov.uk/ssi/2007/434/made	2026-11-12	Confirmed
82	Gesetze im Internet, StGB section 202c	https://www.gesetze-im-internet.de/stgb/__202c.html	2026-11-12	Confirmed (current text)
83	FIRST, CVSS v2	https://www.first.org/cvss/v2/	2026-11-12	Confirmed
84	RFC Editor, RFC 4871	https://www.rfc-editor.org/rfc/rfc4871	2026-11-12	Confirmed
85	NIST, SP 800-94	https://csrc.nist.gov/pubs/sp/800/94/final	2026-11-12	Confirmed
86	NIST, SP 800-38D	https://csrc.nist.gov/pubs/sp/800/38/d/final	2026-11-12	Confirmed
87	NIST, SP 800-90 (June 2006)	https://csrc.nist.gov/pubs/sp/800/90/final	2026-11-12	Confirmed
88	Shumow and Ferguson, CRYPTO 2007 rump session slides	https://rump2007.cr.yp.to/15-shumow.pdf	2026-11-12	Confirmed
89	NIST, SHA-3 project	https://csrc.nist.gov/projects/hash-functions/sha-3-project	2026-11-12	Confirmed

#	Source	URL	Opened	Grade
90	OWASP, Top 10 2007 (PDF)	https://wiki.owasp.org/index.php/Special%3AFilePath/OWASP_Top_10_2007.pdf	2026-11-12	Confirmed; Inferred (the overstated and understated reading)
91	MITRE, CWE news archive, 2007	https://cwe.mitre.org/news/archives/news2007.html	2026-11-12	Confirmed
92	MITRE, CWE news archive, 2008	https://cwe.mitre.org/news/archives/news2008.html	2026-11-12	Confirmed
93	MITRE, About CAPEC	https://capec.mitre.org/about/index.html	2026-11-12	Confirmed
94	Microsoft, Windows Vista lifecycle	https://learn.microsoft.com/en-us/lifecycle/products/windows-vista	2026-11-12	Confirmed
95	NIST, United States Government Configuration Baseline	https://csrc.nist.gov/projects/united-states-government-configuration-baseline	2026-11-12	Confirmed
96	MITRE ATT&CK technique pages for the 2007 mappings (T1498, T1499, T1040, T1203, T1210, T1189, T1566.001, T1584.005, T1190)	https://attack.mitre.org/techniques/T1584/005/ ; https://attack.mitre.org/techniques/T1498/	2026-11-12	Confirmed (the pages); Inferred (the bindings)
97	TeamStarWolf library, `case-studies/ECOMMERCE_THREATS.md` (home study, section 2.2)	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/case-studies/ECOMMERCE_THREATS.md	2026-11-12	Confirmed
98	TeamStarWolf library, `case-studies/` tree (homes for 2007 events: CYBERCRIME_FOUR_BOOKS.md, STUXNET.md, THREAT_ACTORS_RUSSIA.md, THREAT_ACTORS_CHINA.md, THREAT_ACTORS_OTHER_STATES.md, THREAT_ACTORS_UNITED_STATES.md, HACKER_AND_THE_STATE_CASES.md, ZERO_DAY_MARKET_EVENTS.md, SANDWORM_OPERATIONS.md)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/case-studies	2026-11-12, 2026-11-13	Confirmed
99	TeamStarWolf library, `data/attack/technique_profiles.jsonl` (names and tactics)	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_profiles.jsonl	2026-11-13	Demonstrated
100	TeamStarWolf library, `data/attack/` (groups, software, campaigns, group-to-technique and ICS technique data)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-13	Demonstrated
101	TeamStarWolf library, `data/weaknesses/cwe.jsonl` and `data/weaknesses/capec.jsonl`	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/weaknesses	2026-11-13	Demonstrated; Inferred (the study's CWE classes)
102	TeamStarWolf library, `data/attack/technique_to_d3fend.jsonl`	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_to_d3fend.jsonl	2026-11-13	Demonstrated; Inferred (the pairings)
103	TeamStarWolf library, `mitre/` page tree (technique, group, software, campaign, CAPEC, D3FEND and mitigation pages)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/mitre	2026-11-13	Demonstrated

#	Source	URL	Opened	Grade
104	TeamStarWolf library, chronicle Navigator layers (`navigator/library-layers/chronicle-2016.json` and `navigator/case-studies/`)	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/navigator	2026-11-13	Demonstrated
105	NVD API, CVE-2007-6166	`https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2007-6166`	2026-11-13	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents, Threat Actors, Malware Families, CVE Reference
- CWE Reference, CAPEC Reference, D3FEND Reference, Privacy Engineering, GRC and Compliance, Vulnerability Management, Incident Response, Vulnerability Root Causes, ICS/OT Security, ICS ATT&CK Atlas
- Home studies: E-Commerce Threats; Four Books on Cybercrime; Stuxnet; Russia-attributed threat actors; China-attributed threat actors; Other state-attributed actors; United States-attributed threat actors; The Hacker and the State; The Zero-Day Trade and Its Fallout; Sandworm operations; Ransomware ecosystem; APT41; ICS attacks and advisories; Log4Shell; SolarWinds SUNBURST; npm supply-chain attacks; Hugging Face supply chain
- Series: 1993, 1994, 1995, 1996, 1997, 1998, 1999, 2000, 2001, 2002, 2003, 2004, 2005, 2016, 2017, 2018, 2019, 2020, 2021, 2022, 2023, 2024, 2025, 2026
- Techniques: T1566.001 Spearphishing Attachment, T1204.002 Malicious File, T1203 Exploitation for Client Execution, T1189 Drive-by Compromise, T1210 Exploitation of Remote Services, T1190 Exploit Public-Facing Application, T1053.003 Cron, T1046 Network Service Discovery, T1584.005 Botnet, T1498 Network Denial of Service, T1498.001 Direct Network Flood, T1499.001 OS Exhaustion Flood, T1499.002 Service Exhaustion Flood, T1491.002 External Defacement, T1105 Ingress Tool Transfer, T1669 Wi-Fi Networks, T1040 Network Sniffing; APT1 object techniques T1566.002, T1583.001, T1588.001, T1003.001, T1550.002
- CAPEC: CAPEC-8, CAPEC-14, CAPEC-62, CAPEC-63, CAPEC-66, CAPEC-88, CAPEC-98, CAPEC-100, CAPEC-125, CAPEC-126, CAPEC-137, CAPEC-157, CAPEC-158, CAPEC-163, CAPEC-193, CAPEC-300, CAPEC-482

- Groups, software and campaigns: APT1 G0006 and BISCUIT S0017; APT28 G0007; APT5 G1023; Darkhotel G0012; Stuxnet S0603; BlackEnergy S0089; Flame S0143; Sandworm Team G0034; C0028
- Navigator layers, including this study's layers, chronicle-2007.json and chronicle-2007-ics.json